

移动端同意管理平台 隐私风险的理解与分析

Understanding and Analyzing Privacy Risks in
Mobile Consent-Management Platforms

Jingzhou Ye* · Fares Alharbi* · Luyi Xing · Xueqiang Wang

University of Central Florida

Indiana University Bloomington

University of Illinois Urbana-Champaign

IEEE Symposium on Security and Privacy 2026

非官方中文译本，仅供课程学习与论文研读使用。论文版权归原作者及出版机构所有；如中文表述与英文原文存在差异，以英文原文为准。

摘要

当今的移动应用（app）越来越多地重用第三方SDK 来提供基本功能。然而，将这些 SDK集成到应用的供应链中会带来复杂性，使得管理 SDK 并确保其集体遵守隐私法规变得具有挑战性。最近，同意管理平台（CMP）出现，越来越多地被移动应用采用作为集中机制和应用全局配置来帮助管理 SDK，特别是使应用中的所有 SDK 能够在个人数据处理方面遵守相同的用户同意状态。然而，采用既定的 CMP 是否可以确保用户同意的有效性（特别是在移动应用中）的问题仍有待探讨。本研究通过对现实世界移动应用（跨 Android 和 iOS）中使用 CMP界面 获取用户同意相关问题进行首次系统调查，解决了这一知识空白。为了实现这一目标，我们开发了一个新颖的框架 DIULENS，它使用一系列专为 CMP 定制的大语言模型辅助 GUI 分析技术来高效、全面地发现 CMP界面。该框架分析 CMP界面 和应用内的实际 SDK使用情况，以识别 CMP的隐私可问责设计、实施和使用的违规行为（CMP DIU风险或简称 DIU风险）。我们的研究结果揭示了各种 DIU风险，例如未能正确且一致地披露第三方SDK、用户与 CMP界面 交互导致的模糊同意效果，以及难以撤回或强制同意的情况。归因于原因，我们发现应用开发者对 CMP的使用（或配置）和有缺陷的 CMP实现或其组合都可能导致 DIU风险。

我们进一步观察到 Android 和 iOS 平台上 CMP的采用和 DIU风险存在差异，这可能受到特定于平台的隐私功能的影响，例如 Apple 的应用跟踪透明度（ATT）框架。这项研究提供了新的见解，并弥合了关于确保 CMP 在移动应用中获得有效用户同意的关键知识差距。*两位作者对这项工作做出了同等贡献。

1 引言

随着移动应用日益渗透到日常生活中，它们也带来了重大的隐私风险。例如，仅在 2024 年，谷歌就屏蔽了 130 万个因过度访问个人数据的应用 [1]，而在 2022 年，苹果公司标记了近 40 万个应用在用户不知情的情况下收集用户数据 [2]。这些风险不仅源于应用开发者编写的代码，而且在很大程度上还源于将各种第三方 SDK（或库）集成到应用的供应链中 [3]、[4]。由于这些 SDK 带来的复杂性，有效管理它们并确保一致和集体遵守主要隐私法规成为一项重大挑战。例如，GDPR [5] 和 COPPA [6] 要求包含 SDK 的应用在任何 SDK 收集或处理个人数据之前获得有效的用户同意，并且该同意满足关键的有效性标准，例如知情、自由给予、具体和明确。然而，由于缺乏有效的机制来管理 SDK 的同意状态，目前移动应用中的 SDK 集成经常被报道违反这些标准 [7]、[8]、[9]、[10]，从而带来法律合规风险。为此，一种行业解决方案是开发同意管理平台（CMP），该平台使应用开发者能够委托收集和管理与其应用内的第三方 SDK 数据实践相关的用户同意。标准化举措，例如 IAB 制定的透明度和同意框架（TCF）[11]，已被引入以指导和标准化 CMP 实现。使用遵循行业标准的既定 CMP 通常有望增强隐私合规性和问责制。

然而，对网站 [12]、[13]、[14]、[15]、[16]、[17]、[18] 使用的 CMP 的研究表明，它们可以通过多种方式导致无效的用户同意，例如通过在 cookie 横幅中使用预先选择的选项。近年来，移动应用越来越多地采用 CMP，采用率从前 100 名 Android 应用中的 6.6% [8] 上升到本研究中的 8.5%，每个应用的平均下载量为 3860 万次。值得注意的是，排名前 100 的应用往往拥有更大的用户群，采用 CMP 的可能性比排名 100 到 200 之间的应用高出 41.7%。这种趋势提出了一个关键问题：采用 CMP，尤其是经过认证符合行业标准的成熟应用，是否能够通过确保移动应用中的有效用户同意来真正确保隐私合规性？回答这个问题并不简单，因为移动 CMP 与网络 CMP 有很大不同。例如，移动 CMP 通常会针对大量多样化的 SDK 提供更详细的隐私披露和更细粒度的请求同意，并且通常涉及更复杂的图形用户界面（GUI）。相比之下，网站 CMP 通常专注于少数广泛的 Cookie 类别。这些差异限制了基于网络的 CMP 研究结果应用于移动应用的程度。目前，行业领导者通常认为使用已建立的 CMP 可确保隐私合规性，正如他们的官方建议 [19]、[20] 中所反映的那样。然而，在移动应用背景下系统评估这一假设的实证研究仍然明显有限。分析移动应用的 CMP 界面。本研究通过调查 Android 和 iOS 这两个领先平台的移动应用中使用 CMP 的潜在问题来填补研究空白。

为了实现这一目标，我们首先通过结合 CMP 中有效同意的关键标准，为 CMP 的隐私可问责设计、实施和使用制定了一套基本规则，称为 DIU 规则。然后，我们开发了一个名为 DIULENS 的新高效框架，用于识别 CMP 界面中潜在的违反这些规则的行为（称为 DIU 风险）。DIULENS 基于 GUI 分析方法，通过引入一系列有针对性的设计来解决 CMP 界面发现和 DIU 风险分析中的挑战，从而推进当前的研究。具体来说，与应用提供的同意对话框通常结构简单且易于探索不同，CMP 界面往往更加复杂，需要不同的用户交互才能完成探索和分析。例如，遵守 TCF 政策的 CMP 通常采用分层 GUI 结构，跨多个互连的 GUI 显示不同级别的信息（例如，整体个人数据使用情况、SDK 和目的的详细列表），并允许不同粒度的同意选择（例如，接受针对特定 SDK 或目的的全部或逐项同意）。为了应对这一挑战，我们设计了几种专为 CMP 量身定制的新的 LLM 引导的 GUI 分析技术，包括用于区分 CMP 界面与应用中其他 GUI 的 CMP 指南感知方法、优先考虑通向 CMP 的导航流的 LLM 引导路径探索，以及对 CMP 内的 GUI 进行稳健和全面探索的策略。另一个挑战来自这样的事实：尽管存在 CMP 的高级指南，但 CMP 界面的实际外观因不同 CMP 和应用而异，因此无法直接查

明 DIU 风险（如之前的研究 [8]、[10] 中所做的那样）。

为了克服这一挑战，我们采用了 LLM 推理规则，允许基于 CMP 界面 和应用中第三方 SDK 的实际使用来推理违规行为，从而实现有效且通用的 DIU 风险检测，同时捕获其表现形式的变化。

真实移动应用中的 DIU 风险

我们的评估证实了 DIULENS 在发现 CMP 界面 方面的效率及其在分析 DIU 风险方面的有效性。为了了解现实世界中的 DIU 风险，我们收集了两组流行的移动应用，包括 9,332 个 Android 应用和 3,496 个 iOS 应用。在这些应用上运行 DIULENS，我们发现 397 个应用（其中集成 CMP 的应用占 60.5%，包括 371 个 Android 应用和 26 个 iOS 应用）至少有一项违反 DIU 规则的行为。分析这些应用揭示了新的发现和证据，表明即使集成了 CMP，与用户同意相关的问题仍然存在，这是由于对隐私不负责任的 CMP 实现及其在应用中的使用 and 配置。例如，集成 CMP 的移动应用中有 41.9% 未能提供有关第三方 SDK 的可信披露信息，例如请求用户同意比应用实际使用的 SDK 数量更多或更少，或者在 CMP 界面 中显示不一致的 SDK 披露信息，这主要是由于应用开发者未能正确配置 CMP。此外，14.9% 的移动应用要么在提供同意后不允许用户访问 CMP 界面，从而难以撤回用户同意，要么强制用户提供同意。具体来说，关于强制同意，我们发现证据表明应用开发者操纵 CMP 配置，使非必要的 SDK（例如分析）看起来对应用功能来说是严格必需的，从而绕过了用户同意。我们还发现一些最受欢迎的 CMP（例如 OneTrust）未能正确提交用户同意选择，这会导致强制用户同意。

此外，8.1% 的集成 CMP 的应用在显示 CMP 界面 之前收集用户个人数据以请求用户同意，并且由于应用开发者在配置 CMP 方面的不良做法以及 CMP 实现的固有局限性，11.7% 的应用包含 GUI 元素或导航路径，导致对用户同意产生模糊影响。最后，我们观察到，与 Android 相比，iOS 应用采用 CMP 的比例较小，这主要是由于 Apple 的应用跟踪透明度（ATT）框架，这凸显了需要更好地集成 CMP 和 ATT，以确保符合平台级（即 Apple）要求和更广泛的隐私法规。有趣的是，我们发现据报告存在 DIU 风险的 iOS 应用比例较小，因为它们对 CMP 的使用通常涉及简化的 CMP 界面，例如根据 ICC 类别 [21] 显示 SDK，而不完全支持符合 TCF 的 GUI。我们正在向受影响的利益相关者（应用开发者和 CMP）披露 DIU 风险，其中一些风险已经得到确认或解决。为了支持未来移动平台上 CMP 研究，我们在 GitHub 上发布了 DIULENS 的源代码以及 SDK、CMP 和移动应用的数据集 [22]。

主要贡献

本文的贡献包括：

● 移动应用 CMP 界面 分析的新技术

我们开发了一个新的 CMP 界面 分析框架，称为 DIULENS，具有针对性的设计，可以高效、有效地发现和分析 CMP 界面。

● 对移动应用 DIU 风险的新认识

通过在现实世界的应用上运行 DIULENS，本研究强调了通过 CMP 界面 获取用户同意相关的各种问题，解决了关于 CMP 的采用是否确保移动应用隐私合规性的知识差距，并进一步为 CMP 的隐私可问责设计、实施和使用提供信息。

2 背景

数据处理中的用户同意

用户同意在保护数字隐私方面发挥着核心作用。例如，GDPR [23] 第 6(1)(a) 条将同意视为处理个人数据的合法依据，而 COPPA [6] 第 312.5 条要求家长同意收集儿童数据，CCPA [24] 第 1798.120 条要求出售或共享此类数据需要家长同意。这些隐私法规需要用户同意才能满足关键标准才能有效。例如，根据 GDPR，有效的用户同意必须 (1) 自由给予 [25]，有真正的选择，没有压力或胁迫，(2) 知情 [25]，基于清晰且可访问的信息，(3) 具体 [26]，与明确定义的目的相关，(4) 明确 [26]，对个人的意图毫无疑问，(5) 基于明确的肯定性操作 [26]，例如单击“接受”按钮，(6) 在处理任何个人数据之前获得 [26]，以及 (7) 与提供时一样容易撤回 [27]。

同意管理平台 (CMP)

对于软件开发人员来说，获得有效同意是一项艰巨的任务，因为最近的研究 [10]、[12]、[17]、[28]、[29]、[30]、[31]、[32]、[33]、[34] 经常无法满足获得用户同意所需的标准。最重大的挑战之一是越来越多地采用第三方SDK，例如用于广告、分析和其他目的的 SDK。为了应对挑战并确保合规性，许多软件开发人员依赖已建立的同意管理平台 (CMP) 来处理用户同意的获取、管理和记录。图 1 说明了 CMP 处理移动应用用户同意的工作流程。移动应用开发人员首先将第三方 SDK 和 CMP 集成到应用中。CMP 提供 GUI 来告知最终用户有关 SDK 的数据实践并收集他们的同意。一旦获得同意，CMP 可以将相应的同意信号存储在设备的存储器中。然后可以将该信号传递给第三方 SDK，使它们能够根据用户的同意选择进行操作。第三方 SDK 还可以在继续数据收集之前主动查询 CMP 以获取同意信号。通常建议应用开发者尽早初始化 CMP 并显示其 GUI [35]，最好是在应用启动时，在第三方 SDK 开始任何数据处理之前。除此之外，为了支持撤销同意，CMP 界面通常还集成到应用内的其他区域。最终用户 应用开发者 移动应用 集成第三方 SDK 和 CMP 第三方 SDK CMP 同意信号存储 存储同意信号 收集用户同意 获取同意信号 传递同意信号

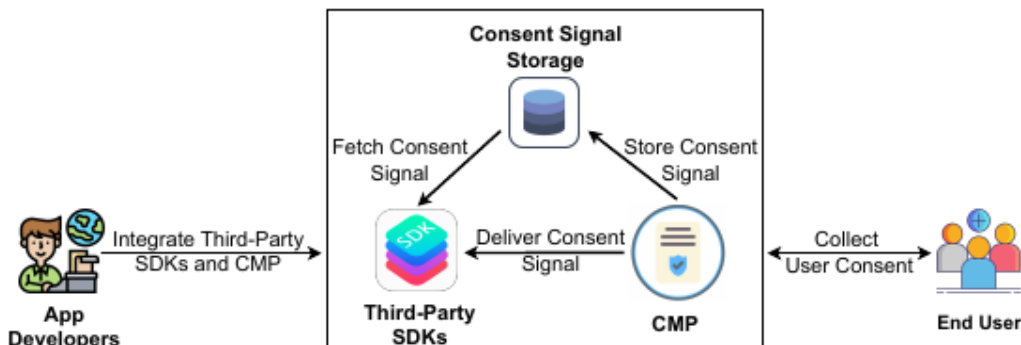


图1：CMP处理用户同意的工作流程。CMP收集用户选择、存储同意信号，并向第三方SDK传递或提供该信号。

其他平台（例如网站）上的 CMP 工作流程遵循类似的模式，CMP 本质上接管了管理用户同意的责任。

透明度与同意框架（TCF）

透明度和同意框架（TCF）[11] 是 IAB Europe 开发的标准，用于管理用户同意以确保数字广告中的 GDPR 合规性。TCF 指定了标准化用户同意的编码和通信的同意字符串。它还通过其全球供应商列表（GVL）为参与的广告技术供应商（或 SDK）提供集中注册，该列表概述了供应商的数据处理活动和目的。它还提供了 CMP 的实施指南，包括 GUI 设计的建议。特别是，符合 TCF 的 CMP 应采用分层 GUI 方法进行同意管理，而不是依赖于单一的同意对话框。初始 GUI 层应显示关键信息，例如 SDK 的数量、其数据实践的摘要以及明确的同意选项（例如“全部接受”、“拒绝”或“管理选项”）。后续层应提供更详细的同意信息，包括 SDK 的全面列表、其特定的数据处理目的以及用户逐项管理同意的选项。图 2 显示了领先的 CMP Usercentric [36] 的初始层和第二层 GUI。如今，几乎所有主要 CMP（例如，[37] 中报告的前 10 名中的 10 名）均已通过 IAB 认证，并被验证符合 TCF。为了在同意管理方面为应用开发者提供更多选择和灵活性，一些 CMP 还支持替代框架。一个例子是国际商会开发的 ICC 框架 [21]，它将网站 cookie 分为严格必要性、性能和功能等类别，从而以用户友好的方式组织同意选项。

尽管最初是为网站 cookie 设计的，但一些 CMP 已采用类似的分类方案来管理移动平台上的 SDK，即将 SDK 分为这些类别 [38]。

3 CMP隐私可问责设计、实现与使用规则

CMP 有助于获取和管理用户对应用使用的 SDK 处理个人数据的同意。同意有效且符合隐私要求

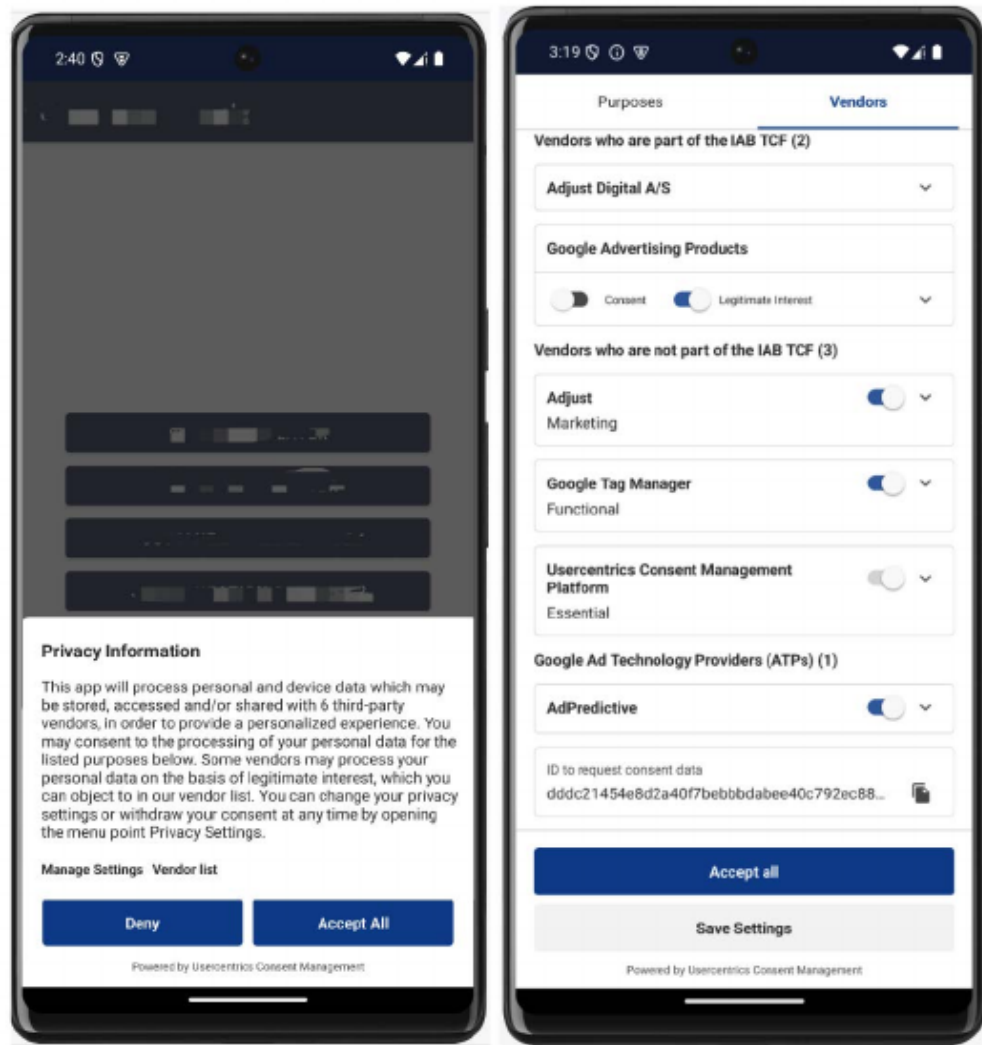


图2: Usercentrics CMP的第一层与第二层界面。第一层提供概览和主要选择, 第二层展示供应商、目的与细粒度设置。

通过结合 CMP的标准, 我们提出了四项规则(概述如下)来指导、定义和规范现实应用中 CMP的隐私可问责设计、实施和使用。这些被称为 CMP 设计、实现和使用规则, 统称为 DIU规则。

DIU规则1: CMP界面的出现时机

CMP界面 应该让用户指定是否同意(或拒绝)单个 SDK进行数据收集或收集目的。规则 1 与 CMP 界面 应在应用中显示的时间有关。根据主要隐私法规[5]、[35]、[39]的要求, 在收集个人数据之前必须获得用户同意。在 CMP的上下文中, 应在任何 SDK 开始收集个人数据之前显示请求同意的应用的 CMP界面。

DIU规则2：CMP界面披露信息的可信性

应用中的 CMP界面 必须可靠地披露有关所使用的各个 SDK的信息，使用户能够为 SDK的数据收集和目的提供知情同意 [40]。规则 2 要求 CMP界面上 SDK的披露信息准确无误。根据我们对 CMP指南 [21]、[35] 的分析，披露的信息通常包括第三方SDK的数量、SDK列表、其法律依据状态、处理数据的目的以及收集和处理的数据的类别。为确保准确性，所披露的信息必须与应用的实际 SDK集成实践保持一致。例如，CMP界面上披露的 SDK数量必须与集成到应用中的实际数量匹配。

DIU规则3：可撤回且不受强迫的用户同意

隐私法规，例如 GDPR 第 7(3) [27] 条，规定用户有权随时撤回同意。在 CMP的背景下，应用应确保在用户最初同意（或拒绝）后 CMP界面 仍可访问，从而允许用户轻松撤回或修改其对 SDK的同意状态（可撤回用户同意）。此外，用户对 CMP界面的同意必须由用户自由给出[35]。例如，如果应用的功能并非绝对必要，则应允许用户拒绝任何 SDK的数据收集或收集的特定目的（非强制用户同意）。

DIU规则4：用户与CMP界面交互所产生的同意效果应明确无歧义

知情同意的一个关键前提是用户通过 CMP界面 的导航始终会产生清晰、明确的同意效果。此要求可适用于每个用户与 CMP界面 的交互或 CMP 内的导航路径。例如，当用户单击按钮或更改复选框的状态时，应清楚地显示最终的同意状态。此外，用户通过多个 CMP界面 的导航应该提供一致的体验，没有任何模糊的用户体验。上述 DIU规则是根据我们对有效同意要求的理解而制定的（考虑 GDPR 等隐私法规）。它们并不意味着完整，而是旨在涵盖 CMP界面 应满足的最低要求。请注意，我们专注于捕获影响所获得的用户同意的有效性并在最终用户与 CMP界面 交互中体现的规则，而不强调其他方面，例如不直接与最终用户交互的同意信号的后端处理。

4 DIULENS的设计

为了能够对集成到移动应用中的 CMP 中的 DIU 风险进行实际分析，我们开发了一个新的自动化框架，称为 DIULENS，其工作流程由四个步骤组成。图 3 提供了 DIULENS 的概述。第一步是数据收集，收集真实世界的移动应用、CMP 和第三方 SDK 进行分析。第二步涉及 CMP 和 SDK 使用情况分析，通过静态和动态应用分析技术来识别 CMP 和 SDK 的实际集成以及它们在应用内的动态使用跟踪。第三步是 LLM 辅助的 CMP 界面分析，它调整 LLM 的使用以有效地发现 CMP 界面。最后一步是 DIU 风险检测，大语言模型通过 CMP 界面和 SDK 使用信息进行推理，以实现通用 DIU 风险检测。DIULENS 的输出包括与违反 DIU 规则 (§ 3) 相对应的已识别 DIU 风险，以及违规原因的潜在归因。下面，我们介绍每个步骤，重点介绍有效 DIU 风险分析所面临的挑战以及我们为应对这些挑战而设计的 CMP 目标。

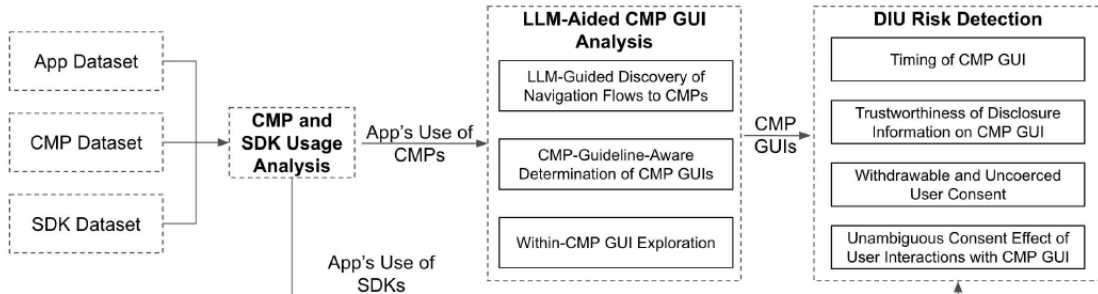


图3: DIULENS总体架构。系统依次执行数据收集、CMP与SDK使用分析、LLM辅助的CMP界面分析和DIU风险检测。

4.1 数据收集

数据收集步骤构建了两套应用，一套适用于 Android，一套适用于 iOS，以及 CMP 及其涵盖的主要 SDK列表。

Android应用

为了收集 Android 应用，我们使用 Google Play Scraper [41] 来获取 54 个 Google Play 类别中每个类别中排名靠前的免费应用的包名称，例如健康与健身、教育、金融和工具。有了包名称，我们就可以使用为 APKPure [42] (Google Play 的替代应用商店 [43]) 构建的自定义爬虫以 APK 或 XAPK 文件的形式下载应用代码。这个替代应用商店被认为是官方 Google Play 的镜像 [43]，并且由于缺乏对 Google Play 的 API 访问，通常被研究人员 [44]、[45] 用于获取应用代码。截至 2024 年 11 月，我们总共收集了每个 Google Play 类别中排名前 200 个应用的软件包名称，从而得出 10,588 个唯一的软件包名称。我们成功下载了 9,332 个独特应用的代码；其余应用在 APKPure 上不可用。

iOS应用

我们从流行的 App Store 分析平台 Appfigures [46] 获取了顶级免费 iOS 应用及其应用 ID 的列表。对于每个应用，我们使用 IPATool [47] 下载其代码（IPA）。然后，我们使用 libimobiledevice 工具包 [48] 在 iPhone 上安装应用，并使用 Frida iOS dump [49] 解密它们。我们保留原始IPA文件和解密后的IPA文件，使用前者进行动态分析，后者进行静态分析。同样是在 2024 年底，我们成功获取了 3,496 个 iOS 应用。CMP。我们收集了以下 CMP：（1）已通过 IAB Europe 的合规性检查（或认证），以及（2）具有可供应用开发者使用的移动 SDK。具体来说，我们首先收集“TCF v2.2 CMP服务（移动）”[50] 的 CMP 列表中出现的 CMP。然后，我们通过手动探索 CMP的官方网站来验证移动 SDK的存在。截至2024年，已有53个CMP列入CMP列表（移动），其中21个已确认已发布移动SDK，其中21个支持Android平台，19个支持iOS平台。对于 21 个 CMP中的每一个，我们收集了其网站、软件包名称（适用于 Android）和框架名称（适用于 iOS，如果平台受支持）。SDK。CMP 有助于收集用户对各种第三方SDK的同意。为了实现全面的 SDK 覆盖，我们从几个著名的 SDK 注册服务机构收集了 SDK 名称及其元数据（例如网站、包名称和服务类型）：（1）IAB 全球供应商列表 [51]、（2）Google 广告技术提供商（ATP）[52] 和（3）Google Play SDK 索引 [53]。这些来源涵盖了各种服务类型的广泛 SDK，例如通常嵌入到移动应用中的广告、分析和实用程序。

请注意，ATP 和 Google Play SDK Index 发布的 SDK 并不限于 Android 平台，因为许多 SDK，尤其是最流行的 SDK，往往涵盖多个平台。我们总共收集了 1,858 个独特 SDK的信息。

4.2 CMP与SDK使用分析

检测应用中的CMP与SDK集成

我们进行静态应用分析，以确定 CMP 和 SDK 是否集成到应用中。具体来说，对于Android应用，我们使用Soot [54]对代码进行反编译和转换，然后分析应用中包含的包。我们通过检测 CMP 和 SDK的包名称是否出现在应用代码中来检查它们是否存在。对于 iOS 应用，我们解压其 IPA 文件并遍历 Payload 目录来识别框架（.framework 文件）或动态库（.dylib 文件），它们对应于 CocoaPods、SPM 和 Carthage 等领先包管理器通常支持的动态链接 SDK。我们通过验证应用使用的框架是否包含 CMP的框架名称来检查 CMP 是否存在。在不太常见的情况下，iOS 应用可以通过静态链接集成 SDK。为了适应这种情况，我们在 iOS 应用二进制文件（Payload/<应用名称>.app/<应用名称> 处的 Mach-O 文件）上使用 otool [55] 来提取符号并检查 SDK 名称是否存在。此步骤通过检查代码的外观来报告集成到应用中的 CMP 和 SDK的列表。此类信息将（1）帮助 DIULENS 将分析范围缩小到集成CMP的应用，（2）为 CMP界面上的 SDK 披露信息提供参考，以检测 DIU风险。

分析SDK与CMP的动态使用轨迹

对于同时包含 CMP 和 SDK 代码的应用，我们会进行动态分析，以了解这些 CMP 和 SDK 在运行时的使用方式，特别是在个人数据访问和用户同意管理方面。为此，我们执行流量和 UI 分析。具体来说，我们首先收集一个 API 列表，这些 API 可以从几个开源隐私工具访问个人数据，例如 Android 的 Camille [56] 和 PrivacySentry [57]，以及 iOS 的 Lalaine [58]。该列表包括 12 个类别的 73 个 Android API，例如位置数据访问和设备标识符，以及 5 个类别的 140 个 iOS API，例如访问照片和联系人。当应用通过 UI 交互执行时（第 4.3 节），我们使用 Frida 挂钩这些 API 并记录每次调用的堆栈跟踪。我们匹配堆栈跟踪帧中的包名称或框架名称，以确定个人数据访问是否源自 SDK 代码。同时，我们确定在应用执行期间何时向用户显示 CMP 界面（如第 4.3 节中详述）。此步骤的输出是一系列带有时间戳的事件，包括个人数据处理和 CMP 界面的显示。

4.3 LLM辅助的CMP界面分析

在本节中，我们将介绍 CMP 界面分析技术，其特点是有针对性的设计，以确保效率和全面的 GUI 发现。

感知CMP指南的CMP界面判定

确定应用 GUI 是否与隐私相关的典型方法涉及分析隐私相关内容，例如使用“隐私”、“cookie”和“数据保护”等关键字检测隐私对话框[8]、[10]。然而，正如第 5.1 节中所评估的，这些方法无法可靠地识别 CMP 界面。虽然与隐私相关的关键字也可能出现在 CMP 界面中，但仅靠它们是不够的，因为应用开发者实现的许多其他 GUI（例如隐私政策页面和非 CMP 隐私对话框）也包含这些关键字。我们的观察是，CMP 通常根据隐私相关框架（例如 TCF 政策 [35]）指定的高级指南（或要求）来实施 GUI。然而，CMP 界面的详细布局和内容可能因不同的 CMP 提供商而异，甚至在应用开发者之间也会有所不同，因为 CMP 通常是可配置的（如第 6 节中所示）。因此，确定 CMP 界面需要一种了解 CMP 指南的方法，重点关注指南中描述的 CMP 界面的性质，而不是特定的 UI 内容（例如与隐私相关的关键字）。受此启发，我们设计了一种基于大语言模型的方法，其中应用 UI 由大语言模型评估，以确定其与 CMP 的相关性。具体来说，我们使用 Appium [59]（一种跨 Android 和 iOS 平台自动化移动应用的开源工具）来推动应用 UI 的探索并提取 UI 信息。对于每个应用 UI，我们首先从 Appium 提供的页面源（中间布局文件）中提取所有 UI 元素，包括它们的属性，如名称、标签、坐标、大小等。接下来，我们将这些 UI 元素以及总结 CMP 界面性质的提示一起输入到 LLM 中，以评估 UI 是否符合 CMP 界面的资格。

图 9（附录）说明了源自 TCF 政策 [35] 和 ICC 指南 [21] 中概述的用户界面要求的提示。评估结果（第 5.1 节详述）证实，与基于关键字的方法 [8] 相比，该方法在确定 CMP 界面方面实现了高覆盖率（84.8%）和精度（100.0%），而基于关键字的方法的覆盖率为 55.9%，精度为 37.9%。

LLM引导的CMP导航路径发现

显示 CMP界面 的一般建议是在应用启动时显示它们，以确保隐私合规性 [60]，例如，在收集任何个人数据之前获得同意。然而，根据隐私法规 [27] 和 TCF 政策 [35] 等行业标准的要求，应用必须重新显示 CMP界面，以允许用户撤回同意。重新显示 GUI 的导航流（或路径）未定义，并且通常在不同的应用中有所不同，具体取决于特定的应用 UI 设计。在应用中发现这些 CMP界面 并非易事，但对于全面分析至关重要。然而，大多数公开的 UI 练习器都是覆盖率驱动的 [61]、[62]、[63]、[64]，其主要目标是增加应用测试覆盖率，而不是专门针对特定类型 GUI 的发现。为了弥补这一差距，我们设计了一个 LLM 引导的 GUI 练习器，旨在有效发现 CMP的导航流。该练习器由两个关键组件组成：（1）通向已知 CMP界面 的导航流程的先验知识，以及（2）指导 GUI 探索优先级的提示。具体来说，我们首先通过审查集成CMP的 24 个应用（选自 5 个 CMP 网站上列出的合作伙伴或客户，但未包含在我们的移动应用数据集中）来构建先验知识，并确定了通往 CMP界面 的 11 个导航流。每个流程都用与用户与 GUI 交互相对应的文本标签列表进行描述（例如，在导航流程中单击的按钮标签）。接下来，我们制作了一个提示（如附录中的图 10 所示），它将通向当前 GUI 的导航流程、GUI 上的所有可点击元素（由 Appium 提取）以及先验知识作为输入。

然后，提示会生成一个输出，根据将导航流程推进到更接近 CMP界面 的可能性，对可点击元素进行排名。Appium 可以根据有序元素与当前 GUI 进行交互。在此提示下，导航流的探索很大程度上遵循深度优先的搜索策略，由 CMP 特定知识驱动。当新的 CMP界面 出现时，探索过程终止；一旦应用从 CMP界面 导航到非 CMP界面，探索过程就会重新启动。当所有应用 GUI 都已探索完毕或达到时间限制时（这是移动应用分析中的常见做法 [65]），探索结束。我们在第 5.1 节中的评估证明了这种 LLM 引导的发现过程相对于最先进的 GUI 探索方法具有显著优势。

CMP内部图形用户界面探索

与应用开发者开发的同意对话框（通常由交互有限的简单单页 GUI 组成）不同，CMP 具有更复杂的 GUI 结构，通常涉及多个互连的屏幕。分析 CMP 需要彻底探索所有 CMP界面 及其内部的交互。发出随机 UI 事件 [66] 是一个潜在的解决方案，因为它确保了 UI 的广泛覆盖。然而，一个重大挑战阻碍了该方法在 CMP 内导航时的有效应用。CMP界面 通常包含“接受”或“拒绝”选项等元素，与这些选项交互时，可能会导致探索因导航离开当前 CMP 而提前结束。为了解决这个问题并确保 CMP界面 探索的效率和覆盖范围，我们开发了两种管理 CMP 内 GUI 交互的策略。第一个是延迟交互策略，我们将与 CMP 退出选项的交互延迟到最晚的可能时刻。为了实现这一点，我们根据对前 10 个 CMP 文档的手动分析，手动编制了与可能导致 CMP 退出的 UI 元素相关的八个关键字（即接受、批准、允许、拒绝、拒绝、保存、确认、关闭）的列表 [37]。对于 CMP中的每个 GUI，我们识别包含这些关键字的 GUI 元素，并保留与它们的交互，直到探索结束。第二个是记录和重放策略。具体来说，对于每个 GUI，我们通过对 Appium 中同时具有非空名称和标签属性的静态 GUI 元素的组合进行哈希处理来生成 GUI 指纹。

然后，我们在运行时将每个导航路径记录为一系列 GUI 指纹，其中每个指纹与一系列 GUI 内事件相关联，例如对可点击元素的点击、滚动操作以及垂直滚动量。如果退出前尚未完全探索 CMP，Appium 脚本将根据记录的导航路径重播 GUI 交互，并恢复与其余 GUI 元素的交互。这些组合策略实现了 CMP界面 的高效率和覆盖率，总体 CMP界面 覆盖率达到 84.8%，与随机点击相比，在相同的时间内识别出更多的 GUI，而随机点击通常会导致 CMP界面 异常退出。

4.4 DIU风险检测

由于 CMP实现的多样性及其在移动应用中的使用不一致，使用高级 DIU规则（§ 3）检测违规行为提出了实际挑战。例如，Koch 等人的先前工作。[8] 依赖于基于规则的系统，使用正则表达式和硬编码启发式来检测同意对话框违规行为。虽然对网站上使用的 CMP 进行大规模分析非常有效，但他们的方法缺乏灵活性，并且通常无法在移动应用中的不同 CMP界面 之间进行推广。因此，有效检测 DIU风险需要一种新方法，根据规则稳健评估 CMP界面 和 SDK使用情况，同时确保捕获这些违规行为的各种表现形式的普遍性。为了满足这一需求，我们提出了一种基于大语言模型的 DIU 风险检测方法，利用大语言模型对与规则相关的 GUI 进行语义推理的能力所引入的通用性。您是识别移动应用内同意管理平台（CMP） GUI 问题的专家。您将获得以下信息：

- CMP界面 屏幕截图：CMP界面 屏幕截图的 URL 列表，其中包含指示 GUI 何时显示的时间戳。例如，
`[("https://a.com/1st_layer .png", "2025-02-12T14:30:00"), ("https://a.com/2nd_layer.png", "2025-02-12T14:31:00")]` 表示两个 GUI 屏幕截图。
- CMP界面 导航流：UI 导航事件列表，每个事件包括源 GUI、目标 GUI 和触发操作。例如，两个 CMP 层之间的导航：
`[("1st_layer.png", "2nd_layer.png", "click '管理选项'按钮")]`。
- SDK使用数据：列出 SDK 数量、名称和服务类型的句子。

例如：这个应用使用了50个第三方SDK，包括Adjust（分析），...，以及<忽略以减少空间>。

- SDK数据访问事件：由 SDK 发起的一系列数据访问事件，带有指示事件发生时间的时间戳，例如
`[("2025-02-12T14:29:30Z", "AppLovin", "访问设备标识符")]`。使用上述信息，检查是否违反以下规则：<带有示例性示例的 DIU规则。> 请注意：
 - 您应该根据每条规则评估 CMP界面、导航流程、SDK使用数据和数据访问事件。
 - 对于每个应用，您的回答应根据规则编号，以“是”（违规）或“否”（无违规）开头，如果是“是”，则后跟一句话描述。
 - 对于低可信度违规行为，请勿报告“是”。

You are an expert in identifying problems in the GUIs of consent management platforms (CMPs) within mobile apps. You will be provided with the following information:

- **CMP GUI Screenshots:** A list of URLs for CMP GUI screenshots, with timestamps indicating when the GUIs were displayed. For example, `[("https://a.com/1st_layer.png", "2025-02-12T14:30:00"), ("https://a.com/2nd_layer.png", "2025-02-12T14:31:00")]` represents two GUI screenshots.

- **CMP GUI Navigation Flows:** A list of UI navigation events, each including the source GUI, destination GUI, and the triggering action. For example, navigation between two CMP layers: `[("1st_layer.png", "2nd_layer.png", "click 'Manage options' button")]`.

- **SDK Usage Data:** Sentences listing the number of SDKs, their names, and service types. For example: This app uses 50 third-party SDKs, including Adjust (analytics), ..., and <ignored to reduce space>.

- **SDK Data-Access Events:** A sequence of data-access events initiated by the SDKs with timestamps indicating when the events occur, e.g., `[("2025-02-12T14:29:30Z", "AppLovin", "Accessing Device Identifiers")]`.

Using the above information, check for violations of the rules below: <DIU rules with exemplary examples.>

Note that:

- You should evaluate the CMP GUIs, navigation flows, SDK usage data and data-access events against each rule.

- For each app, your response should be numbered according to the rules, starting with "YES" (violation) or "NO" (no violation), followed by a one-sentence description if "YES".

- Do not report "YES" for low-confidence violations.

图4: 用于DIU风险检测的大语言模型提示词。输入结合CMP界面、导航路径、SDK使用信息和数据访问事件。

融合CMP与SDK使用数据的LLM提示词

该方法的核心是 LLM提示，它描述了应用的 CMP界面 和 SDK使用信息，有效地使移动应用代码适合基于 LLM 的分析。如图 4 所示，提示首先定义 LLM 在分析 CMP界面 中的角色、指定输入格式、列出检测规则并概述预期的输出格式。我们设计输入以涵盖不同的视角，包括单个 CMP界面、跨不同 GUI 或 SDK使用和 CMP界面 之间。具体来说，输入包括第 4.3 节中提取的 CMP界面 屏幕截图列表。这些屏幕截图标有在 CMP界面 分析期间出现的时间戳，并且大语言模型可以通过指向存储在 Dropbox 中的图像的 URL 来访问这些屏幕截图 [67]。我们还为大语言模型提供通往每个 CMP界面 的导航流程，以前面的 GUI 列表以及触发下一个 GUI 显示的相应 GUI 交互的形式。该提示还包括 SDK使用信息，例如所使用的 SDK的数量和列表、其服务类型，以及由 SDK 发起的带时间戳的数据访问事件序列。输入中包含 CMP界面、GUI 导航流（通过 CMP界面 分析识别，第 4.3 节）和 SDK使用数据（通过静态和动态应用分析收集，第 4.2 节），提示将能够通过一组可扩展的 LLM 推理规则检测 DIU风险（我们将在后面说明）。

检测DIU风险的推理规则

我们根据 § 3中概述的DIU规则设计了用于检测DIU风险的LLM推理规则。具体来说，对于DIU规则1，LLM将SDK使用信息中的数据访问事件的时间戳与CMP界面屏幕截图的时间戳进行比较，以确定是否有任何SDK在获得用户同意之前访问用户个人数据。DIU规则 2 的推理规则会比较 SDK使用信息和 CMP界面 屏幕截图，以识别 CMP界面 中 SDK 相对于应用实际使用的 SDK 过度披露和不足披露的情况。它还检查跨 CMP界面 的 SDK 披露，以识别 SDK信息中的任何不一致之处。DIU规则 3 的推理规则侧重于检查应用是否允许用户通过重新显示 CMP界面（特别是通过易于访问的路径）来撤回同意。此外，该规则还将检查 CMP界面 是否允许用户自由设置非严格必要的 SDK 和数据处理目的的同意状态，以及当前 CMP界面 是否允许用户明确确认其更改（例如，通过保存按钮）。最后，DIU规则 4 的推理规则检查各个 CMP界面 及其导航路径，以确定：（1）任何用户操作（例如按钮单击）是否可能导致误导性的同意状态，以及（2）沿导航路径跨 GUI 的任何用户交互是否在视觉上或语义上具有误导性。图 4 中的规则部分提供了推理规则的摘要。

DIU风险归因

DIU风险可能来自各个利益相关者，包括实施 CMP的 CMP 开发人员、将 CMP 集成到其应用中的应用开发者，或有时两者兼而有之。对于报告的每个 DIU风险，我们都会尽最大努力通过跨应用分析来识别潜在来源。直观上，我们可以根据应用使用的 CMP 对应用进行分组。对于使用相同 CMP的每组应用，如果所有应用报告相同的 DIU风险，则 DIU风险可归因于 CMP 开发者；否则，将归咎于应用开发者。然而，在实践中，应用开发者可以决定显示哪些 CMP界面 [15]，从而导致一些 DIU风险（即使它们是由 CMP 开发人员引起的）出现在某些应用中，而不会出现在其他应用中。为了补充这一点，我们不仅根据 CMP 名称，还根据应用中显示的 CMP界面 数量进一步细化应用分组。应用开发者的DIU风险主要是由于CMP集成过程中的错误配置造成的。为了进一步调查这些错误配置的潜在原因，我们审查了集成过程，以确定可能使正确配置变得困难的任何与 CMP 相关的因素。

§ 6 报告了本研究中确定的 DIU风险及其对应用和 SDK 开发人员的归因。

5 评估

除非另有说明，所有评估和测量活动均通过从位于挪威的 IP 运行 Android 和 iOS 应用来进行，挪威执行 GDPR 及其同意要求。我们在具有 Android 13 的 root Redmi Note 12 上运行 Android 应用，并在运行 iOS 16.7.10 的越狱 iPhone X 上运行 iOS 应用。我们基于 ChatGPT 的旗舰模型 GPT4o [68] 制作了 DIULENS 原型。该评估旨在回答两个关键研究问题：RQ1：DIULENS 在发现 CMP 界面 方面的有效性是什么，以及它与替代方法相比如何？RQ2：DIULENS 在检测 DIU 风险方面的有效性如何？

5.1 发现 CMP 界面的有效性 (RQ1)

真实标签数据

我们从集成任何 CMP 的应用池中随机抽取了 60 个应用（30 个 Android 和 30 个 iOS）（通过静态应用分析确定），并手动运行它们以发现尽可能多的 GUI。通过这个过程，我们发现 30 个 Android 应用中的 25 个和 30 个 iOS 应用中的 26 个在我们的分析过程中呈现了 CMP 界面。更具体地说，这些应用总共提供了 165 个不同的 CMP 界面，每个应用平均有 3.2 个 GUI。此外，Android 应用提供了 87 个 CMP 界面（每个应用平均有 3.5 个），而 iOS 应用提供了 78 个 CMP 界面（每个应用平均有 3.0 个）。我们使用这些手动识别的 CMP 界面 作为地面真实数据来评估 DIULENS 在发现 CMP 界面 方面的有效性。

评估结果

我们在所有 60 个应用上运行 DIULENS，发现它成功发现了其中 47 个应用中的 CMP 界面。具体来说，DIULENS 在 25 个 Android 应用中成功发现了 24 个 CMP 界面，覆盖了总共 76 个 CMP 界面；在 26 个 iOS 应用中成功发现了 23 个应用，覆盖了 64 个 CMP 界面。值得注意的是，这些 CMP 界面 都不是误报，即它们全部出现在手动发现的 CMP 界面 中。在漏报方面，我们观察到一款 Android 应用不允许对其应用 GUI 进行屏幕截图，而 Appium 无法与其中 3 个 iOS 应用进行交互，从而阻止了 GUI 分析。总体而言，DIULENS 成功发现了 47 个应用中的 140 个 CMP 界面，应用级覆盖率达到 92.2%，GUI 级覆盖率达到 84.8%，没有误报。凭借这种高精度和合理的覆盖范围，我们确保后来报告的 DIU 风险确实与 CMP 界面 相关。

DIULENS 与基于关键词的 CMP 界面判定方法对比

与之前确定 CMP 界面 的方法相比，DIULENS 的优势在于它利用了 CMP 指南感知方法，该方法可适应 CMP 实现中的变化。为了评估这一点，我们将 DIULENS 与类似于 [8] 的基于关键字的方法进行比较。具体来说，对于用于创建真实数据的 30 个 Android 应用，我们使用 Appium 来执行它们，并且对于每个 GUI，在 [8] 中搜索用于识别隐私对话框（包括 CMP 界面）的关键字是否存在。这一过程报告 124 个 GUI，其中至少包含一个关键字。然而，经过手动分析，我们发现这些 GUI 中只有 47 个是实际的 CMP 界面，导致地面真实数据中所有 CMP 界面 的覆盖率仅为 54.0%。基于关键字的方法识别出的其余 77 个 GUI 与 CMP 无关，例如与隐私政策和应用引导屏幕相关的 GUI，精度为 37.9%。与 DIULENS 的精度（100.0%）和覆盖率（84.8%）相比，这种明显的差异凸显了需要更有效的方法来确定 CMP 界面，正如我们在第 4.3 节中提出的那样。请注意，我们仅选择 Android 应用进行评估，因为一旦 Appium 提供了 GUI 的页面源，CMP 界面 的确定就与移动平台无关。

DIULENS与FastBot的CMP导航路径发现能力对比

Fastbot 是一种基于模型的 GUI 测试工具，广泛用于自动化应用 GUI 探索 [69]。我们将其与 LLM 引导的发现 CMP 导航流程的方法进行了比较。具体来说，我们在 30 个 Android 应用上分别运行 FastBot 和 DIULENS 15 分钟，并观察达到的 CMP 数量以及达到它们所花费的时间。我们发现，Fastbot 在时限内仅在 10.0% 的情况下发现 CMP 导航流，总体 CMP 界面 覆盖率为 28.7%。与 DIULENS 实现的 84.8% GUI 覆盖率相比，这一结果证实了使用类似于 Fastbot 的现有工具（不受 CMP 语义指导）来发现 CMP 界面 是不可行的。特别是，我们发现 Fastbot 在两个方面失败了。首先，当 CMP 显示在具有复杂导航流程的隐私设置中时，Fastbot 通常无法发现它们，因为其策略是最大化整体 GUI 覆盖范围，而不是针对 CMP 进行优化。其次，即使在应用启动期间自动呈现一些 CMP，我们发现 Fastbot 经常快速导航离开它们，无法探索进一步的 CMP 界面。这一发现证实了通过强大的 insideCMP 探索来覆盖 CMP 界面 的挑战，我们通过引入两种直观而有效的导航策略来解决这个问题：延迟交互和记录和重放，如第 4.3 节中所述。

5.2 检测DIU风险的有效性（RQ2）

真实标签数据

我们根据第 5.1 节中采样的 30 个 Android 应用构建了 DIU 风险的地面实况数据。具体来说，我们招募了两名隐私研究人员，并向他们提供了这些应用的 87 个 CMP 界面，以及通过静态分析获得的 SDK 使用数据。我们对两名研究人员进行了有关 DIU 规则的培训，并要求他们独立报告这些应用中的 CMP 界面 是否违反了这些规则。研究人员分别报告了 18 个应用中的 32 个和 30 个 DIU 风险，均发现了所有四项规则的潜在违规行为。计算研究人员报告的 Cohen Kappa 表明，他们达成了实质性一致，Kappa 值为 85.4%。随后，我们要求他们仅审查其中一家报告的潜在 DIU 风险，并通过面对面讨论解决任何差异。此过程产生了 18 个应用中 32 个 DIU 风险的真实数据。

评估结果

我们在上述应用上运行 DIULENS，发现它报告了所有 DIU 风险，但有两个误报，检测 DIU 风险的准确率为 94.1%。这两个误报都是由 CMP 界面 元素的隐含含义引起的。例如，据报道，CNN 一款应用违反了 DIU 规则 3，因为用户没有明确保存其同意选择的选项。然而，人工分析证实存在“确定”按钮，其本质上是用于“保存更改”或“确认”的目的。我们认为这仅与可用性相关，而不是真正的违规，因为它不会强制用户提供同意，并且“确定”按钮与同意状态也没有直接关系（这也不构成违反 DIU 规则 4）。

跨LLM的泛化能力

为了进一步验证我们检测 DIU 风险（第 4.4 节）的方法是通用的，并且与特定模型无关，我们用另外两个 LLM（GPT-5 [70] 和 DeepSeek-V3 [71]）替换了 DIULENS 原型实现中的 GPT-4o，并报告了它们在检测 DIU 风险方面的精确度和召回率。当使用 GPT-5 进行评估时，DIULENS 成功识别了所有 32 个真实 DIU 风险，同时将误报减少到 1 个，精度达到 97.0%。相比之下，在 DeepSeek-V3 中，DIULENS 也检测到了所有 DIU 风险，但引入了 4 个误报，准确率达到 88.9%。我们认为 DeepSeek-V3 和 GPT-5 之间的差异主要是由于与 DeepSeek-V3 相比，GPT-5 具有更好的多模态语义理解[72]。然而，尽管存在这些差异，所有评估模型的强劲表现都证明了它们在分析 DIU 风险方面的实际潜力，表明 DIULENS 并不严格依赖于特定的 LLM，并且可以适应不同的后端模型。

6 真实环境中的DIU风险测量

6.1 DIU风险总体情况

表1：CMP检测、CMP界面发现与DIU风险测量结果

指标	Android	iOS	合计	涉及CMP数
总计	9,332	3,496	12,828	15
含CMP代码的应用	675 (7.2%)	159 (4.5%)	834 (6.5%)	12
出现CMP界面的应用	546 (5.9%)	110 (3.1%)	656 (5.1%)	12
存在DIU风险的应用	371 (67.9%)	26 (23.6%)	397 (60.5%)	12
DIU规则1	48 (8.8%)	2 (1.8%)	50 (7.6%)	5
DIU规则2	256 (46.9%)	19 (17.3%)	275 (41.9%)	7
DIU规则3	90 (16.5%)	8 (7.3%)	98 (14.9%)	4
DIU规则4	73 (13.4%)	4 (3.6%)	77 (11.7%)	6

注：总量百分比以平台全部应用为分母；DIU风险及各规则的百分比以出现CMP界面的应用为分母。

应用对CMP的使用情况

我们在 9,332 个 Android 应用和 3,496 个 iOS 应用上运行 DIULENS，以识别那些使用 CMP 的应用，每个应用的平均 LLM 查询成本约为 0.01 美元。通过静态应用分析（第 4.2 节），我们发现 675 个（7.2%）Android 应用和 159 个（4.5%）iOS 应用集成了至少一个 CMP。iOS 应用中 CMP 的集成率低于 Android 应用，我们认为这与苹果应用跟踪透明度（ATT）框架的引入有关[73]。自 iOS 14.5 起，iOS 上的应用需要通过 ATT 框架请求用户同意，专门用于通过设备的 IDFA 跟踪用户。集成 ATT 框架和 CMP 可能会导致应用两次请求类似的同意，从而可能导致令人困惑和令人沮丧的用户体验 [74]。此外，这种情况也让开发人员感到困惑，事实表明，即使是 Google UMP 等领先的 CMP 平台，在 ATT 已经实施的情况下，也曾就是否有必要使用 CMP 提供过含糊不清的指导 [75]。鉴于此，我们怀疑一些 iOS 应用开发者可能由于 ATT 的存在而选择不集成 CMP。然而，值得注意的是，ATT 并不否定用户同意数据处理的要求（使用个人数据用于跟踪目的除外），并且无意取代 CMP [74]、[76]。因此，可能需要更多的工程和研究关注来更好地将 CMP（用于遵守隐私法规）与 ATT（用于 iOS 平台上的合规性）结合起来，以确保与用户同意相关的真正的隐私合规性。

发现1: 由于苹果 ATT 框架的实施, iOS 应用集成的 CMP 往往比 Android 应用少, 这凸显了需要更好地集成 CMP 与 ATT, 以确保符合平台级要求和隐私法规。这些集成 CMP 的应用是最受欢迎的, 在 Android 上平均下载量为 2,865 万次, 在 iOS 1 上有超过 165,000 条评论。DIULENS 进一步在 546 个 Android 应用和 110 个 iOS 应用中识别出了 CMP 界面, 而在其他应用中没有识别出 CMP 界面。我们观察到 37 个 Android 应用的 CMP 界面分析不成功, 原因如下: 19 个应用无法从我们位于挪威的测试位置执行, 10 个应用与测试设备不兼容, 其余 8 个应用要么要求用户下载不可用的资源 (例如游戏资产), 要么被付费墙阻止, 从而阻止了真实应用 GUI 的渲染。同样, 由于 iPhone 上安装的困难 (15 个应用)、Appium 分析 GUI 和执行交互的能力有限 (10 个应用) 以及在我们的评估期间从 App Store 中删除了一些应用 (3 个应用), CMP 界面分析对 28 个 iOS 应用不成功。检测到的 DIU 风险概述。在这些应用中, 有 371 个 Android 应用 (546 个应用中的 67.9%) 和 26 个 iOS 应用 (110 个应用中的 23.6%) 被报告违反了至少一项 DIU 规则。违反最多的规则是 DIU 规则 2 (CMP 界面上披露信息的可信度), 占 Android 上 DIU 风险的 46.9% 和 iOS 上 DIU 风险的 17.3%。iOS 上较低的 DIU 风险率可能归因于采用了更简化的 CMP 界面设计。

例如, 在 Android 上, 366 个 (67.0%) 应用提供了符合 TCF 的 CMP 界面, 其中包括分层 GUI 和 TCF 策略 [35] 定义的丰富内容, 例如 SDK 的详细列表、其用途和同意请求。然而, 只有 31 个 (28.2%) iOS 应用提供了符合 TCF 的 CMP 界面, 而很大一部分 (71.8%) 1. iOS 应用下载数量不显示简化的 GUI, 允许用户管理对几个预定义类别的 SDK 的同意 (类似于 ICC cookie 类别 [21]), 而不是对每个 SDK 逐项同意, 如附录中的图 8 所示。此类 CMP 界面可能会通过省略详细的 SDK 信息 (例如实际数据接收者) 来违反数据透明度原则 [77], 但由于可用于根据 DIU 规则进行评估的 GUI 内容有限, 因此往往会在 DIULENS 中触发较少的违规行为。

发现2: 与通常显示符合 TCF 标准的 CMP 界面的 Android 应用相比, iOS 应用倾向于采用简化的 CMP 界面设计, 该设计无法提供详细的 SDK 信息 (以及真正的数据透明度), 但预定义的 SDK 类别除外。

6.2 违反 DIU 规则 1 的风险

50 个应用 (7.6%) 包含第三方 SDK, 这些第三方 SDK 在显示 CMP 界面之前开始收集个人数据, 违反了 DIU 规则 1 (CMP 界面的计时)。出现这种情况是因为应用开发者经常在加载 CMP 之前错误地初始化一个或多个 SDK。此外, 尽管所有应用都在欧盟 (GDPR 适用的地区) 内进行了测试, 但仍发现 12 个应用显示为 CCPA [24] 设计的 CMP 界面, 旨在保护加州居民。具体来说, 这些应用不会在数据收集开始之前 (例如, 在应用启动时) 请求同意, 而是假定默认情况下允许数据收集, 并且仅在隐私设置中显示 CMP 界面, 以便为用户提供退出选项。进一步的分析表明, 这些应用虽然也为欧盟居民提供服务, 但始终通过硬编码设置 ID 呈现与 CCPA 相关的 GUI, 这表明开发人员可能误解了适用的隐私法规。

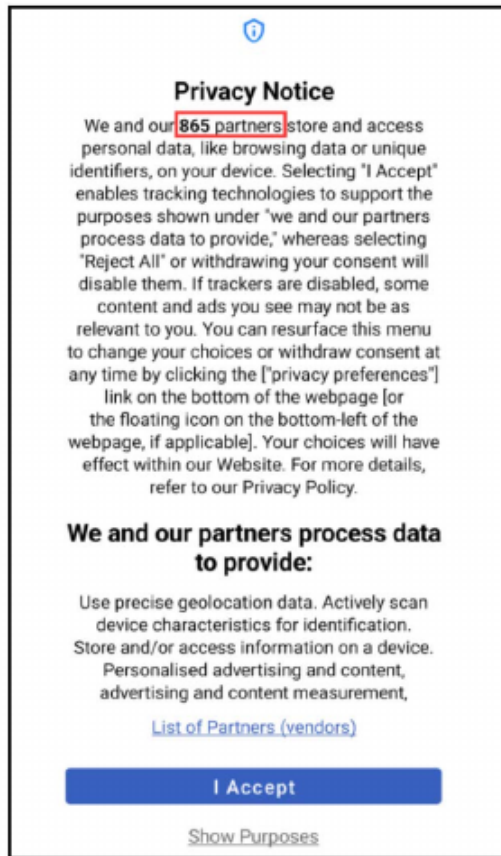
Flip Master案例

是一个使用 Usercentrics CMP的真实示例。该应用直接启动进入游戏，无需预先显示任何 CMP界面。用户只能通过导航到“设置 - 隐私设置”来访问 CMP界面，在那里他们会发现默认情况下打开的“定向广告”选项。此设置意味着只要用户与应用互动，应用就假定用户同意 SDK数据收集。应用中包含 CMP界面的目的只是为了让用户选择退出，而不是征得他们的同意。

发现3: 7.6% 集成CMP的应用在收集用户同意之前访问个人数据，因为应用开发者未能（1）正确协调 CMP 和 SDK的执行顺序，以及（2）配置 CMP 以遵守适用的隐私法规。

6.3 违反DIU规则2的风险

总共有 256 个 (46.9%) Android 应用和 19 个 (17.3%) iOS 应用被报告因不可信（不准确或不正确）的 SDK 披露而存在 DIU风险。这些DIU风险主要体现在两个方面：（1）CMP界面上的SDK披露与SDK使用不一致；（2）不同CMP界面之间的SDK披露不一致。（a）在 9GAG 应用中请求同意过多的 SDK（b）在 Animal Hunter 应用中将营销 SDK 标记为“必需”



(a) Requesting consent for excessive SDKs in the 9GAG app



(b) Labeling marketing SDKs as "essential" in the Animal Hunter app

图5: CMP界面截图示例: (1) SDK信息过度披露; (2) 将营销SDK标记为“必要”。

SDK披露与实际使用不一致

所有分析的应用中，有 214 个（32.6%）存在 DIU 风险，因为 CMP 请求用户同意的 SDK 与应用实际使用的 SDK 不匹配。这些 DIU 风险中的绝大多数表现为过度披露（95.4%），即 CMP 界面 寻求同意的 SDK 数量多于集成的 SDK，而少数风险则是披露不足的情况（4.6%），即 CMP 界面 中提供的 SDK 数量少于实际使用的数量。前者未能提供具体且知情的同意请求，通过不必要的长 SDK 列表压倒用户，导致决策疲劳，并使他们面临不必要的隐私风险[78]，而后者由于缺乏对特定 SDK 处理数据的同意而导致直接隐私侵犯[27]，[39]。过度披露的一个例子是 9GAG 应用，该应用的安装量超过 4400 万次。尽管仅使用 76 个 SDK，但 OneTrust [79] 提供的 CMP 界面 请求同意多达 865 个 SDK（如图 5a 所示）。此问题源于以下事实：OneTrust 默认情况下包含 IAB Vendor 2.2 框架 [11] 中的所有供应商，并要求应用开发者根据应用中实际使用的 SDK 主动检查和配置供应商列表。然而，9GAG 应用的开发者采用了默认设置，而没有根据应用的实际 SDK 使用情况进行定制。Clock Launcher 就是一个未充分披露的例子，它是一款使用 Iubenda 作为 CMP 的闹钟和启动器应用 [80]。Iubenda 提供的 GUI 请求同意空的 SDK 列表，而该应用实际上集成了第三方 SDK，例如 Google Mobile Ads SDK 和 Adjust SDK，这两个 SDK 都处理个人数据（如 IAB 供应商列表 [51] 中所述）。

我们对其他受影响应用的分析揭示了类似的原因：应用开发者要么接受默认的 CMP 配置，而不根据其应用进行定制（与行为研究中观察到的默认效果偏差一致，即用户倾向于坚持默认设置 [81]、[82]），要么在自定义 CMP 时省略 SDK（尽管目前尚不清楚这些遗漏是意外还是故意）。

发现4：近三分之一集成CMP的应用披露了与实际 SDK使用情况不符的不可信 SDK信息。由于应用开发者在集成CMP时未能正确配置 SDK列表，因此绝大多数此类应用都会请求用户同意使用过多的 SDK。除了 214 个应用的 SDK 信息不一致之外，我们还发现 165 个应用未在其 CMP 界面上披露 SDK 信息。具体来说，这些应用将 CMP 配置为仅显示 SDK 类别（类似于附录中的图 8），同时对用户隐藏详细的 SDK 列表（如我们之前在第 6.1 节中所述）。这种做法不符合 TCF 政策 [35]，该政策要求 CMP 界面 提供有关“指定第三方列表”的信息，也不符合 GDPR 第 13 条 [77] 等隐私法规，该法规要求数据控制者身份的透明度。然而，我们从报告中排除了这 214 个应用，因为它们没有明确披露 CMP 界面上不可信的 SDK 信息，而是代表了根本没有披露 SDK 的特殊情况。

不同CMP界面之间的SDK披露不一致

总共有 61 个应用（9.3%）被发现在 CMP 用户界面内部或之间包含不一致的信息。一个突出的例子涉及 50 个应用，全部由 Voodoo [83] 开发，它们集成了 SourcePoint 作为其 CMP。在最初的 CMP 界面 中，这些应用通知用户他们与 36 个合作伙伴（即 SDK）合作。但是，单击“查看所有提供程序”按钮后，用户将看到另一个 GUI，其中包括文本视图和列表视图。虽然文本视图仍然指出使用了 36 个合作伙伴，但列表视图显示了 70 个 SDK。这种 DIU 风险给用户带来了错误的印象，即应用依赖的第三方 SDK 比实际少得多。我们向 Voodoo 报告了这个问题，后者确认差异是由于“文本与合作伙伴计数模块之间取消集成导致的链接问题”造成的，并已解决该问题。此问题影响了我们数据集中集成 SourcePoint 的所有 57 个应用。此外，我们发现四个使用其他 CMP 的应用（例如 Iubenda 和 OneTrust）似乎故意操纵公开的 SDK 数量，进一步加剧了用户的误解。

发现5：某些 CMP 中的实施缺陷以及应用开发者故意操纵 SDK 披露信息，导致 CMP 界面 之间的 SDK 信息不一致。

6.4 违反DIU规则3的风险

据报告，共有 90 个（16.5%）Android 应用和 8 个（7.3%）iOS 应用存在违反 DIU 规则 3（可撤回和非强制用户同意）的 DIU 风险。

不可撤回的用户同意

根据主要隐私法规的规定[24]、[27]、[39]，用户应该能够像给予同意一样轻松地撤回同意。TCF 实施指南 [35] 进一步要求应用开发者（即发布商）提供允许用户撤回同意的可访问设置。然而，运行 DIU 风险显示，15 个（2.5%）应用不包含任何允许用户在给予同意后修改其同意的 GUI。例如，G-SPAN Now（一款使用 OneTrust CMP 的新闻应用）仅在应用初始启动期间提供同意选项。应用运行后，用户无法重新访问或调整他们的同意偏好。应用的设置中完全没有撤回同意的选项，这实际上迫使用户要么永久接受其最初的决定，要么卸载并重新安装应用以重置他们的首选项。

发现6：2.5% 的应用未能提供可访问的 CMP 界面 供用户撤回同意。

受强迫的用户同意

共有 90 个应用（13.7%）被发现强迫用户提供同意，原因要么是应用开发者的做法，要么是 CMP 实现中的缺陷。强制用户同意的主要原因是应用开发者未能（以及潜在的操纵）对 SDK 进行分类，即在 CMP 配置中设置 SDK 类别。以使用 Usercentrics CMP 的 Animal Hunter 应用为例。除了来自 IAB 供应商列表 [51] 和 Google 广告技术提供商 [52] 的 SDK（两者本质上都集成到 Usercentrics 中）之外，CMP 还允许应用开发者手动添加不属于这些列表的 SDK。开发人员可以指定每个 SDK 的名称、描述，以及最重要的类别，例如 Essential、Marketing 或 Function。值得注意的是，标记为“Essential”的 SDK 被视为严格要求的，因此不受同意请求的约束，即默认情况下，用户被视为已授予同意，无法修改此设置。我们观察到，Animal Hunter 应用利用了这一 CMP 功能，该功能旨在支持更广泛的 SDK，将 AppLovin 和 Facebook SDK 等营销 SDK 标记为 Essential（如图 5b 所示），从而迫使用户同意其使用，而无法选择退出。在 78 个应用中发现了类似的 DIU 风险，但外观略有不同。例如，另一个 CMP OneTrust 将 SDK 分为五个 cookie 类别：绝对必要、性能、功能、目标和社交媒体。默认情况下，只有 Strictly Necessary cookie（及其关联的 SDK）被标记为“始终处于活动状态”，以防止用户拒绝它们。

然而，OneTrust 允许应用开发者将任何 cookie 类别配置为“始终处于活动状态”，从而有效地强制用户同意非必要的 SDK。45 个应用（例如 Forever 21）被发现利用了上述配置。我们无法查明此类开发人员行为的明确原因，无论是技术故障还是故意操纵。但对研究文献的回顾表明，一些开发人员的做法可能源于



图6：从“始终启用”的CMP设置跳转到允许用户选择的SDK列表，形成含义不一致的导航路径。

对类别标签的误解。例如，如[84]中所示，功能类别与名称所暗示的不同，并不一定是应用正常运行所必需的；相反，它属于可被视为“额外功能 Cookie”的内容。

发现7：一些领先的 CMP 允许开发人员指定哪些 SDK 是必需的，从而假定他们同意，而不向用户提供选择。有证据表明，应用开发者确实有意或无意地利用了此功能来绕过营销 SDK 的用户同意。强迫用户同意的另一个原因在于 CMP 实现中的缺陷。具体来说，我们发现 56 个应用 (8.5%) 在初始 CMP 界面上包含指向“合作伙伴（供应商）列表”的链接。但是，当用户导航到列表并尝试修改其对某些合作伙伴（即 SDK）的同意首选项时，没有明确的选项来保存更改（例如“保存”或“确认我的选择”按钮），也不会自动保存更改。因此，无论之前的用户选择如何，重新输入合作伙伴列表始终会显示已授予同意。这种 DIU 风险可能会误导用户相信他们的同意偏好已被记录，而实际上这些偏好尚未生效。对这些应用的仔细分析表明，它们都使用 OneTrust 作为 CMP。图 7（在附录中）显示了 OneTrust 提供的初始 GUI 和供应商列表。我们向 OneTrust 报告了此问题，他们目前正在调查该问题。

发现8: 某些 CMP（例如 OneTrust）中的实施缺陷会阻止用户在某些 CMP界面上保存其同意选择。

6.5 违反DIU规则4的风险

总共有 30 个应用（4.6%）被发现具有支持用户交互的 CMP界面，导致对用户同意选择产生模糊影响，可能违反了必须通过明确的肯定性操作获得用户同意的要求 [27]、[39]、[85]。CMP 事实上的标准实现是提供内置 GUI，允许用户对第三方SDK 做出肯定操作，例如“接受全部”或“管理设置”。然而，七个 CMP 被发现允许应用开发者自由定制这些操作的外观，为滥用和同意操纵打开了大门 [36]，[86]。一个例子是使用 Usercentrics CMP的 Animal Hunter 应用。该应用被发现用“Tap to Play”和“Details”取代了两个标准选项，其中“Tap to Play”表明点击它会进入主要内容。但实际上，单击此选项会立即表示同意使用所有 SDK，但所有用户可能不会立即清楚这一事实。应用开发者所做的自定义各不相同，例如，将“全部接受”替换为“确定”、“是”或“继续”。这种定制是否真的会导致隐私侵犯是有争议的，但根据之前对用户隐私认知的研究 [15]，它们确实可能会在用户做出同意选择时造成混乱或误导。

发现9: 应用开发者可以自行决定自定义 CMP界面 元素（例如按钮）的外观，这可能会在用户做出同意选择时造成混乱或误导。歧义不仅发生在单个 CMP界面上，而且还体现在多个 CMP界面之间的导航路径中，在 47 个（7.2%）应用中发现了这种情况。分析显示，所有这些应用都使用 OneTrust 作为其 CMP。值得注意的是，我们观察到这些应用在 CMP界面 中将某些数据处理目的（例如，“匹配并合并来自其他数据源的数据”）列为“始终处于活动状态”，这表明用户不能拒绝这些目的。但是，当用户单击这些目的时，他们会被重定向到另一个 CMP界面，该 GUI 会显示 SDK列表，其中包含切换选项，以同意或拒绝将其用于这些目的。这会产生差异，因为最初的 CMP界面 会导致用户相信该目的无法被拒绝，而后续的 GUI 则允许他们拒绝该目的，从而给应用用户带来混乱和模糊的体验。图 6 显示了此 DIU风险涉及的两个 CMP界面。我们已向 OneTrust 报告此问题，该公司目前正在调查此问题。

发现10: 在跨多个 CMP界面 进行导航时，CMP实现可能会给应用用户带来混乱和不明确的体验，因此除了技术实现之外，还需要对这些 GUI 进行更多以用户为中心的评估。

7 讨论

技术贡献讨论

之前分析 CMP 界面的方法，例如基于正则表达式和启发式的方法 [8]、[10]、[18]，对于其他平台（尤其是 Web）效果很好，其 cookie 横幅布局和内容已在各个网站上标准化或统一。然而，重用这些方法来根据 DIU 规则评估移动 CMP 界面很困难，因为移动 CMP 界面通常由 CMP 和应用在布局、文本和导航流中进行广泛定制。本研究为解决这一问题做出了两项技术贡献：（1）引入了一套通用和基础规则，定义了移动 CMP 的预期（或合规）设计、实施和使用以获得用户同意，即 DIU 规则（§ 3）；（2）设计一个新的基于 LLM 的语义分析管道 DIULENS，它可以在 Android 和 iOS 上的定制和多样化 CMP 界面上对这些规则进行通用评估。

局限性与未来工作

虽然 DIU 规则提供了有用的见解，但它们并不详尽，因此我们的研究结果仅涵盖了当前 DIU 风险的一部分。其他 DIU 风险，例如涉及 CMP 对同意信号进行内部处理的风险，超出了 GUI 中所体现的范围，将在未来的工作中进行探讨。DIULENS 的实施涉及几个实际考虑因素。首先，我们观察到 Android 开发人员经常应用保留 CMP 初始化类的混淆规则 [87]、[88]，而 iOS 开发人员通常保持框架文件名不变。因此，我们通过匹配 Android 上的包名称和 iOS 上的框架名称来检测应用中的 CMP 集成（第 4.2 节），并指出实际上不需要更先进的技术，例如反混淆库检测。其次，单独测试每个 CMP（无需托管它的应用）提供了另一种方法来识别与 CMP 实现相关的一些 DIU 风险。然而，我们选择通过集成 CMP 的应用来分析 CMP，主要是由于实际限制，其中包括许多 CMP 需要许可协议、合同或明确授权才能访问其全部功能，以及不平凡的配置工作，这阻碍了现实场景中的可扩展性和代表性分析。

负责任披露

我们正在负责任地披露我们的发现。由于涉及大量利益相关者（例如应用开发者和 CMP），我们的策略是优先向受影响应用数量最多的应用开发者和受 DIU 风险影响最大的 CMP 进行报告。到目前为止，我们已向三个应用开发者（涵盖 94 个不同的应用）和一个涵盖 26 个应用的 CMP 提供商发送了详细的 DIU 风险报告，包括 CMP 标识符、屏幕截图和描述。总的来说，我们收到了两种回复：一种（例如 Voodoo）确认了 DIU 风险并已实施修复，而另一种仍在调查中。

8 相关工作

先前的研究 [12]、[13]、[14]、[15]、[16]、[17]、[18] 广泛研究了与 CMP 管理的网站 cookie 横幅相关的隐私风险。这些研究强调了一系列合规性问题，包括在用户做出任何选择之前存储同意（即默认同意）、缺乏退出选项以及使用预先选择的选择来引导用户同意[12]、[13]、[15]。研究人员还发现，网站往往无法尊重用户的偏好，即使在用户选择退出后仍继续收集和共享个人数据[12]、[13]、[14]、[16]。为了检测和分析此类违规行为，已经开发了多种工具。例如，研究[14]、[17]建议使用客户端工具来识别同意字符串生成和传输中的问题。CookieBlock [18] 进一步通过应用机器学习对 cookie 进行分类并直接在浏览器中强制用户同意，显示超过 94% 的网站至少存在一种类型的 GDPR 违规行为。虽然这些技术在 Web 环境中有效，但在很大程度上依赖于特定于浏览器的功能，例如 JavaScript 检测、HTTP cookie 标头和客户端同意字符串 - 集成到移动应用中的 CMP 中通常不具备这些功能。相反，移动应用通常依赖于本地存储、专有 SDK 接口或后端 CMP API，使得现有的基于 Web 的 CMP 分析技术难以直接应用。在移动平台上，多项研究表明，应用开发者实施的同意对话框可能会带来类似的风险[7]、[8]、[9]、[10]，包括缺乏有意义的退出选项和不遵守用户选择。

然而，这些研究主要关注内部实施，而不是 CMP，后者由于更广泛的采用而变得越来越重要。例如，2023 年进行的一项研究 [8] 发现，排名前 100 的应用中只有 6.6% 采用了 CMP。相比之下，我们使用 2024 年底收集的应用（比 [8] 晚一年左右）进行的研究表明，排名靠前的应用中 CMP 的采用率显著增加（Android 上为 7.2%，iOS 上为 4.5%），这可能是受到监管压力和处理个人数据的第三方 SDK 的广泛使用推动的。这一趋势强调了对移动应用中 CMP 的设计和使用进行系统调查的必要性。为了解决这一差距，我们引入了用于 CMP 界面分析的新工具，并提出了有关其合规行为的新颖的实证研究结果。

9 结论

这项研究揭示了与在移动应用中使用同意管理平台（CMP）相关的问题。我们首先通过具体化有效用户同意的关键标准，为 CMP 的隐私可问责设计、实施和使用设计规则。接下来，我们开发了一个新的 CMP 界面分析框架 DIULENS，以分析移动应用中 CMP 中违反这些规则的情况。我们的研究结果表明，尽管采用了 CMP，但仍然存在重大问题，包括 CMP 界面中 SDK 的不可信披露、请求同意之前的 SDK 数据处理、不可撤回和强制用户同意，以及用户与 CMP 界面交互导致的模糊同意效果。这些结果凸显了应用开发者需要改进 CMP 实现和配置，以确保遵守隐私法规。

致谢

作者要感谢匿名审稿人和牧羊人富有洞察力和建设性的反馈。UCF 作者部分得到 UCF 种子资助计划和 NSF 拨款号 2520321 的支持。IU 作者部分得到 NSF 拨款 CNS-2330265 的支持。

参考文献

参考文献保留英文，以便与原文引用编号逐项对应。

- [1] A. Vakulov, “Google play’s security: 2.36 million apps blocked for violations in 2024,” *Forbes*, 2025. [Online]. Available: <https://www.forbes.com/sites/alexvakulov/2025/02/02/googleplays-security-236m-apps-blocked-for-violations-in-2024/>
- [2] S. Gatlan, “Apple blocked 1.7 million apps for privacy, security issues in 2022,” *BleepingComputer*, 2023. [Online]. Available: <https://www.bleepingcomputer.com/news/apple/apple-blocked-17-million-apps-for-privacy-security-issues-in-2022/>
- [3] M. H. Meng, C. Yan, Y. Hao, Q. Zhang, Z. Wang, K. Wang, S. G. Teo, G. Bai, and J. S. Dong, “A large-scale privacy assessment of android third-party sdks,” *arXiv preprint arXiv:2409.10411*, 2024.
- [4] I. Reyes, P. Wijesekera, J. Reardon, A. Elazari Bar On, A. Razaghpanah, N. Vallina-Rodriguez, and S. Egelman, “‘won’t somebody think of the children?’ examining coppa compliance at scale,” in *The 18th Privacy Enhancing Technologies Symposium (PETS 2018)*, 2018.
- [5] European Union. (2016) General data protection regulation (gdpr). [Online]. Available: <https://gdpr-info.eu/>
- [6] Federal Trade Commission, “Children’s online privacy protection rule (coppa),” <https://www.ftc.gov/legal-library/browse/rules/childrens-online-privacy-protection-rule-coppa>, 2023.
- [7] S. Li, Z. Yang, Y. Nan, S. Yu, Q. Zhu, and M. Yang, “Are we getting well-informed? an in-depth study of runtime privacy notice practice in mobile apps,” in *Proceedings of the 2024 on ACM SIGSAC Conference on Computer and Communications Security*, 2024, pp. 1581–1595.
- [8] S. Koch, B. Altpeter, and M. Johns, “The {OK} is not enough: A large scale study of consent dialogs in smartphone applications,” in *32nd USENIX Security Symposium (USENIX Security 23)*, 2023, pp. 5467–5484.
- [9] T. T. Nguyen, M. Backes, N. Marnau, and B. Stock, “Share first, ask later (or never?) studying violations of {GDPR}’s explicit consent in android apps,” in *30th USENIX Security Symposium (USENIX Security 21)*, 2021, pp. 3667–3684.
- [10] T. T. Nguyen, M. Backes, and B. Stock, “Freely given consent? studying consent notice of third-party tracking and its violations of gdpr in android apps,” in *CCS 2022*, 2022, pp. 2369–2383.
- [11] IAB Europe, “Iab europe transparency & consent framework policies,” 2024. [Online]. Available: <https://iab europe.eu/transparencyconsent-framework/>
- [12] C. Matte, N. Bielova, and C. Santos, “Do cookie banners respect my choice?: Measuring legal compliance of banners from iab europe’s transparency and consent framework,” in *2020 IEEE Symposium on Security and Privacy (SP)*. IEEE, 2020, pp. 791–809.
- [13] A. Bouhoula, K. Kubicek, A. Zac, C. Cotrini, and D. Basin, “Automated {Large-Scale} analysis of cookie notice compliance,” in *33rd USENIX Security Symposium (USENIX Security 24)*, 2024, pp. 1723–1739.
- [14] M. A. B. Aziz and C. Wilson, “Johnny still can’t opt-out: Assessing the iab ccpa compliance framework,” *Proceedings on Privacy Enhancing Technologies*, 2024.
- [15] M. Nouwens, I. Liccardi, M. Veale, D. Karger, and L. Kagal, “Dark patterns after the gdpr: Scraping consent pop-ups and demonstrating their influence,” in *Proceedings of the 2020 CHI conference on human factors in computing systems*, 2020, pp. 1–13.
- [16] Z. Liu, U. Iqbal, and N. Saxena, “Opted out, yet tracked: Are regulations enough to protect your privacy?” *Proceedings on Privacy Enhancing Technologies*, 2024.
- [17] M. Zhang, W. Meng, Y. Zhou, and K. Ren, “Cschecker: revisiting gdpr and ccpa compliance of cookie banners on the web,” in *Proceedings of the IEEE/ACM 46th International Conference on Software Engineering*, 2024, pp. 1–12.
- [18] D. Bollinger, K. Kubicek, C. Cotrini, and D. Basin, “Automating cookie consent and {GDPR} violation detection,” in *31st USENIX Security Symposium (USENIX Security 22)*, 2022, pp. 2893–2910.
- [19] Google, “Set up your consent banner with a consent management platform or a content management system,” 2024. [Online]. Available: <https://support.google.com/analytics/answer/14546213?hl=en>
- [20] Google., “Google consent management requirements for serving ads in the eea, the uk, and switzerland for cmps,” <https://support.google.com/admanager/answer/13554020>, 2024.
- [21] I. C. of Commerce, “Icc uk cookie guide,” 2025. [Online]. Available: https://www.mqmentalhealth.org/wp-content/uploads/icc_uk_cookiesguide_revnov.pdf
- [22] SPIRIT-security, “DIUens,” <https://github.com/SPIRIT-security/DIUens>, 2025.
- [23] European Union, “Art. 6 lawfulness of processing,” <https://gdpr-info.eu/art-6-gdpr/>, 2016.
- [24] California Department of Justice, “California consumer privacy act (ccpa),” <https://oag.ca.gov/privacy/ccpa>, 2024.
- [25] European Parliament and Council, “Recital 42 of the General Data Protection Regulation (GDPR),” <https://gdpr.eu/recital-42-consentrequirements/>, 2016.
- [26] E. Parliament and Council, “Recital 32 of the General Data Protection Regulation (GDPR),” <https://gdpr.eu/recital-32-consent/>, 2016.
- [27] European Union, “Art. 7 gdpr – conditions for consent,” <https://gdprinfo.eu/art-7-gdpr/>, 2016.

- [28] I. Arkalakis, M. Diamantaris, S. Moustakas, S. Ioannidis, J. Polakis, and P. Ilia, “Abandon all hope ye who enter here: A dynamic, longitudinal investigation of android’s data safety section,” in 33rd USENIX Security Symposium (USENIX Security 24), 2024, pp. 5645 – 5662.
- [29] N. Alomar and S. Egelman, “Developers say the darnedest things: Privacy compliance processes followed by developers of child-directed apps,” Proceedings on Privacy Enhancing Technologies, 2022.
- [30] C. Tagliaro, F. Hahn, R. Sepe, A. Aceti, and M. Lindorfer, “I still know what you watched last sunday: Privacy of the hbbtv protocol in the european smart tv landscape,” in 30th Annual Network and Distributed System Security, NDSS 2023, 2023.
- [31] Y. Zhang, Z. Hu, X. Wang, Y. Hong, Y. Nan, X. Wang, J. Cheng, and L. Xing, “Navigating the privacy compliance maze: Understanding risks with {Privacy-Configurable} mobile {SDKs},” in 33rd USENIX Security Symposium (USENIX Security 24), 2024, pp. 6543 – 6560.
- [32] □. Feal, P. Calciati, N. Vallina-Rodriguez, C. Troncoso, and A. Gorla, “Angel or devil? a privacy study of mobile parental control apps,” Proceedings on Privacy Enhancing Technologies, 2020.
- [33] K. Kollnig, A. Shuba, R. Binns, M. Van Kleek, and N. Shadbolt, “Are iphones really better for privacy? comparative study of ios and android apps,” arXiv preprint arXiv:2109.13722, 2021.
- [34] Z. Liu, U. Iqbal, and N. Saxena, “Opted out, yet tracked: Are regulations enough to protect your privacy?” arXiv preprint arXiv:2202.00885, 2022.
- [35] IAB Europe, “Iab europe transparency & consent framework policies,” 2024. [Online]. Available: <https://iabeurope.eu/iab-europetransparency-consent-framework-policies/>
- [36] Usercentrics, “Usercentrics – automate privacy compliance. drive marketing growth,” <https://usercentrics.com/>, 2025.
- [37] Cookiebot, “10 of the best consent management platforms (cmps) compared,” 2025. [Online]. Available: <https://www.cookiebot.com/en/best-consent-management-platforms/>
- [38] OneTrust, “View and categorize scan results,” <https://developer.onetrust.com/onetrust/docs/view-and-categorize-scan-results>, 2025.
- [39] European Data Protection Supervisor, “eprivacy directive,” https://www.edps.europa.eu/data-protection/our-work/subjects/eprivacy-directive_en, 2024.
- [40] European Union. (2016) General data protection regulation (gdpr) – informed consent. [Online]. Available: <https://gdpr-info.eu/issues/consent/>
- [41] F. Olano, “google-play-scraper,” <https://github.com/facundoolano/google-play-scraper>, 2022.
- [42] APKPure, <https://apkpure.com>, 2014.
- [43] G. P. Store, <https://play.google.com/store>, 2012.
- [44] P. Calciati, K. Kuznetsov, A. Gorla, and A. Zeller, “Automatically granted permissions in android apps: An empirical study on their prevalence and on the potential threats for privacy,” in Proceedings of the 17th International Conference on Mining Software Repositories, 2020, pp. 114 – 124.
- [45] A. Razagallah, R. Khoury, and J.-B. Poulet, “Twindroid: A dataset of android app system call traces and trace generation pipeline,” in Proceedings of the 19th International Conference on Mining Software Repositories, 2022, pp. 591 – 595.
- [46] Appfigures, “Appfigures – app intelligence, and analytics,” <https://appfigures.com/>, 2025.
- [47] Majd, “ipatool: Command-line tool for downloading and managing ios apps,” 2025. [Online]. Available: <https://github.com/majd/ipatool>
- [48] libimobiledevice contributors, “libimobiledevice: A cross-platform library for interacting with ios devices,” 2025. [Online]. Available: <https://github.com/libimobiledevice/libimobiledevice>
- [49] AloneMonkey, “frida-ios-dump: A tool for dumping ios app executables,” 2025. [Online]. Available: <https://github.com/AloneMonkey/frida-ios-dump>
- [50] IAB Europe, “Consent management platform(cmp) list,” <https://iabeurope.eu/cmp-list/>, 2025.
- [51] I. Europe, “Tcf vendor list,” <https://iabeurope.eu/vendor-list-tcf/>, 2025.
- [52] Google, “Ad technology providers,” <https://support.google.com/admanager/answer/9012903?hl=en>, 2025.
- [53] Google, “Google play sdk index,” <https://play.google.com/sdks>, 2025.
- [54] S. Team, “Soot: A java optimization framework,” 2025. [Online]. Available: <https://soot-oss.github.io/soot/>
- [55] Otool, “otool – a tool for extracting objective-c runtime information from mach-o files,” <https://github.com/Imposter/otool>, 2020.
- [56] J. Zheng, “Camille: Detecting and characterizing location exposure in android apps,” 2021. [Online]. Available: <https://github.com/zhengjim/camille>
- [57] Y. Allen, “Privacysentry: Federated learning for detecting privacy violations in mobile apps,” 2021. [Online]. Available: <https://github.com/allenymt/PrivacySentry>
- [58] Y. Xiao, Z. Li, Y. Qin, X. Bai, J. Guan, X. Liao, and L. Xing, “Lalaine: Measuring and characterizing non-compliance of apple privacy labels at scale,” arXiv preprint arXiv:2206.06274, 2022.
- [59] A. Contributors, “Appium: A mobile automation framework,” 2025. [Online]. Available: <https://github.com/appium/appium>

- [60] Usercentrics, “Integrating usercentrics,” https://docs.usercentrics.com/cmp_in_app_sdk/latest/integration/intro-collect/, 2024.
- [61] Google, “Monkey: Randomized testing,” <https://developer.android.com/studio/test/other-testing-tools/monkey>, 2025.
- [62] A. Machiry, R. Tahiliani, and M. Naik, “Dynodroid: An input generation system for android apps,” in Proceedings of the 2013 9th joint meeting on foundations of software engineering, 2013, pp. 224–234.
- [63] T. Cai, Z. Zhang, and P. Yang, “Fastbot: A multi-agent modelbased test generation system,” in Proceedings of the IEEE/ACM 1st International Conference on Automation of Software Test, 2020, pp. 93–96.
- [64] C. Peng, Z. Zhang, Z. Lv, and P. Yang, “Mubot: Learning to test large-scale commercial android apps like a human,” in Proceedings of the 38th International Conference on Software Maintenance and Evolution (ICSME 2022), 2022.
- [65] H. Wang, Y. Fang, Y. Liu, Z. Jin, E. Delph, X. Du, Q. Liu, and L. Xing, “Hidden and lost control: on security design risks in iot user-facing matter controller,” 2025.
- [66] S. R. Choudhary, A. Gorla, and A. Orso, “Automated test input generation for android: Are we there yet?(e),” in 2015 30th IEEE/ACM International Conference on Automated Software Engineering (ASE). IEEE, 2015, pp. 429–440.
- [67] Dropbox User, “Dropbox,” <https://www.dropbox.com/>, 2008.
- [68] OpenAI, “Gpt-4o technical report,” <https://openai.com/index/gpt-4o>, 2024.
- [69] Z. Lv, C. Peng, Z. Zhang, T. Su, K. Liu, and P. Yang, “Fastbot2: Reusable automated model-based gui testing for android enhanced by reinforcement learning,” in Proceedings of the 37th IEEE/ACM International Conference on Automated Software Engineering, 2022, pp. 1–5.
- [70] OpenAI, “Gpt-5 technical report,” <https://platform.openai.com/docs/models/gpt-5>, 2025.
- [71] DeepSeek-AI, “Deepseek-v3 technical report,” 2024. [Online]. Available: <https://arxiv.org/abs/2412.19437>
- [72] A. Rahman, S. H. Mahir, M. T. A. Tashrif, A. A. Aishi, M. A. Karim, D. Kundu, T. Debnath, M. A. A. Moududi, and M. Eidmum, “Comparative analysis based on deepseek, chatgpt, and google gemini: Features, techniques, performance, future prospects,” arXiv preprint arXiv:2503.04783, 2025.
- [73] Apple Inc., “App tracking transparency,” 2024. [Online]. Available: <https://developer.apple.com/documentation/apptrackingtransparency>
- [74] Didomi, “App tracking transparency (ios 14.5+),” Aug. 2024. [Online]. Available: <https://developers.didomi.io/cmp/mobile-sdk/ios/app-tracking-transparency-ios-14>
- [75] A. Vaish, “Implementation of google cmp along with att for ios apps,” 2024. [Online]. Available: <https://groups.google.com/g/google-admob-ads-sdk/c/0YoMmgwstNE>
- [76] Usercentrics GmbH, “Does att replace a cmp?” https://docs.usercentrics.com/cmp_in_app_sdk/latest/overview/att/#doesatt-replace-a-cmp, 2025.
- [77] European Union, “Art. 13 gdpr - information to be provided where personal data are collected from the data subject,” <https://gdpr-info.eu/art-13-gdpr/>, 2016.
- [78] B. W. Schermer, B. Custers, and S. Van der Hof, “The crisis of consent: How stronger legal protection may lead to weaker consent in data protection,” Ethics and information technology, vol. 16, no. 2, pp. 171–182, 2014.
- [79] OneTrust, “Onetrust - trust intelligence platform,” <https://www.onetrust.com/>, 2024.
- [80] iubenda, “iubenda - compliance software for websites and apps,” <https://www.iubenda.com/en/>, 2024.
- [81] C. Santos, M. Nouwens, M. Toth, N. Bielova, and V. Roca, “Consent management platforms under the gdpr: processors and/or controllers?” in Annual Privacy Forum. Springer, 2021, pp. 47–69.
- [82] N. C. Council, “Deceived by design: How tech companies use dark patterns to discourage us from exercising our rights to privacy. (2018),” 2018.
- [83] V oodoo, “V oodoo | entertain the world,” <https://voodoo.io/>, 2013.
- [84] S. Jiwani, R. Sasheendran, A. Abhyankar, E. Bouma-Sims, and L. Granor, “Crumbling cookie categories: Deconstructing common cookie categories to create categories that people understand,” Proceedings on Privacy Enhancing Technologies, 2024.
- [85] European Union, “Art. 4 gdpr - definitions,” <https://gdpr-info.eu/art-4-gdpr/>, 2016.
- [86] UniConsent, “Uniconsent - universal consent management platform,” <https://www.uniconsent.com/>, 2017.
- [87] SourcePoint, “android-cmp-app: Android consent management platform sdk,” 2025. [Online]. Available: <https://github.com/SourcePointUSA/android-cmp-app>
- [88] “Android app implementation sdk,” <https://support.inmobi.com/choice/how-to-guide/integrate-the-tag-or-sdk/android-app-implementation-sdk#overview>, InMobi Support, 2025.
- [89] F. He, Y. Jia, J. Zhao, Y. Fang, J. Wang, M. Feng, P. Liu, and Y. Zhang, “Maginot line: Assessing a new cross-app threat to piias-factor authentication in chinese mobile apps,” in Network and Distributed System Security Symposium (NDSS), 2024.
- [90] B. Tang, D. Bui, and K. G. Shin, “Navigating cookie consent violations across the globe,” in Proceedings of the 34th USENIX Conference on Security Symposium, 2025, pp. 5817–5836.

附录A

补充图示与提示词

图 7 显示了 OneTrust 的 CMP 界面，它允许用户修改其同意选择，但不提供保存这些修改的显式选项。因此，用户的同意选择没有被正确记录。图 8 展示了一个 iOS CMP 界面，允许用户管理多个预定义 SDK 类别的同意，类似于 ICC cookie 类别 [21]。图 9 显示了用于确定 UI 是否符合 CMP 界面 资格的提示，以 TCF 策略 [35] 和 ICC 指南 [21] 中的用户界面要求为指导。图 10 显示了用于识别可点击 UI 元素的提示，这些元素可能会将导航流程推进到 CMP 界面。

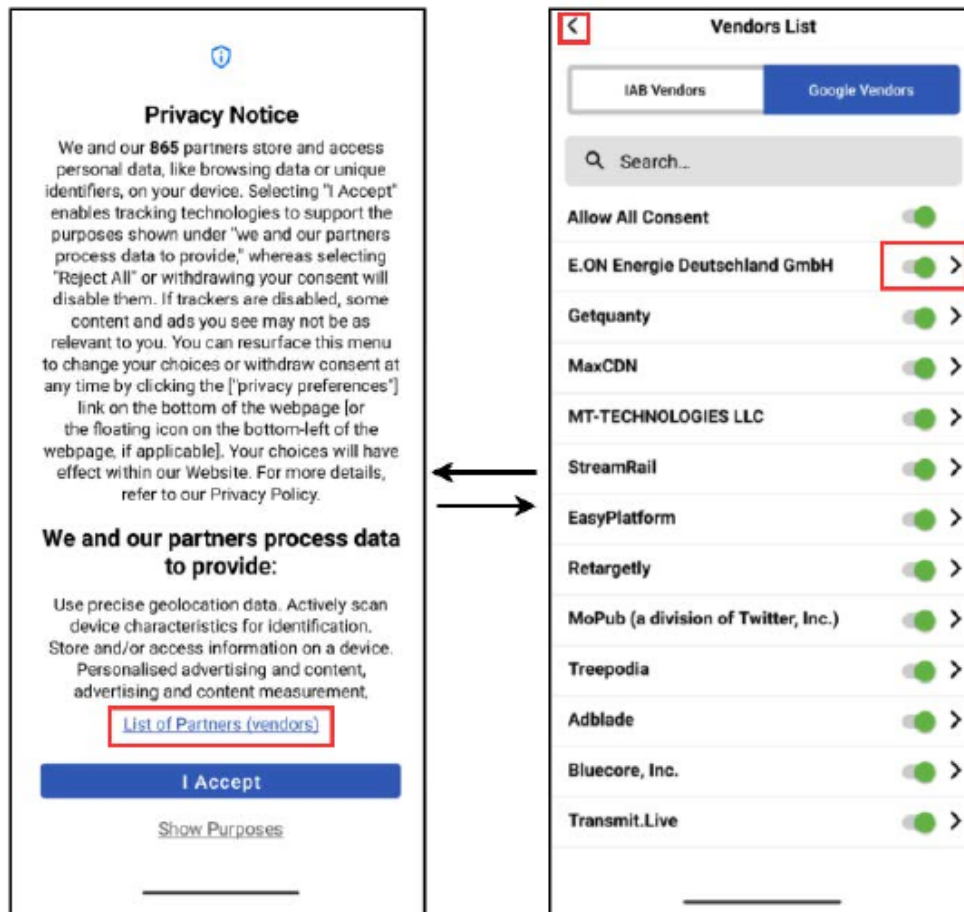


图7：OneTrust CMP界面未能提供明确的保存选项，用户修改后的同意选择无法生效。

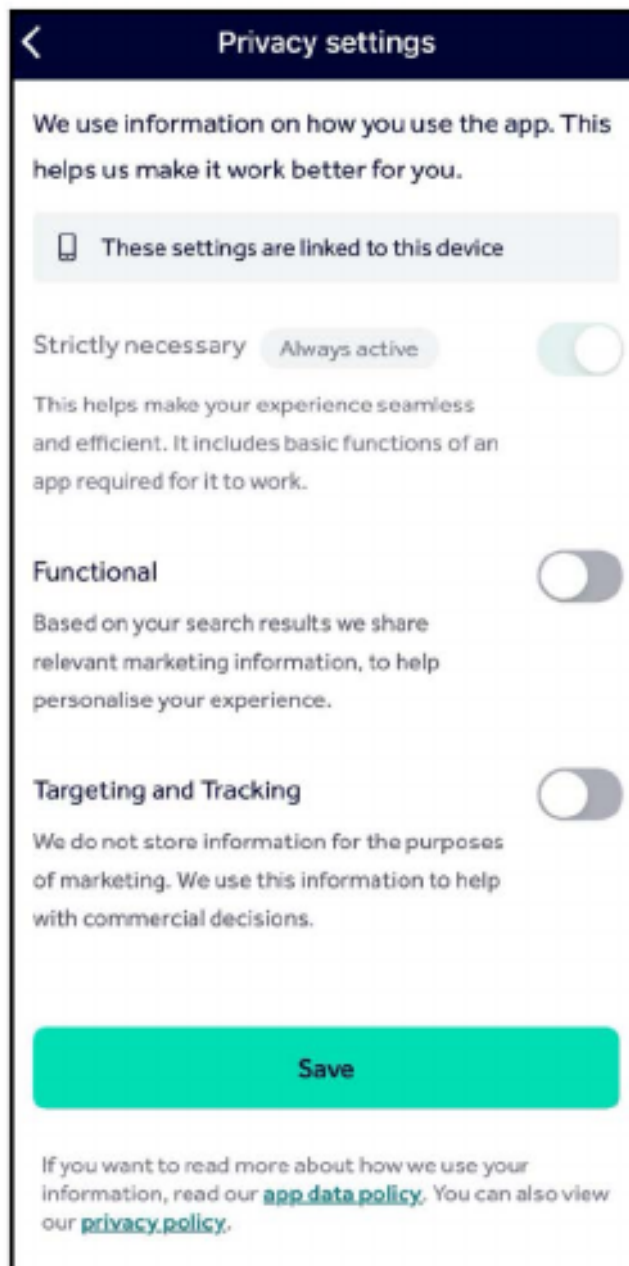


图8：一个iOS CMP界面，按预定义SDK类别提供同意管理。

做出决策时，请记住 CMP界面 通常具有以下目的之一：（1）作为初始 CMP界面，提供以下信息：

- 信息存储在用户设备上并从用户设备访问（例如，cookie、设备标识符和其他设备数据）；
- 个人数据被处理的事实以及所处理的个人数据的性质；
- 第三方供应商将参与数据处理、供应商数量以及完整供应商列表的链接；
- 数据处理目的清单；
- 有关供应商在处理数据时使用的特殊功能的信息；
- 有关同意选择范围的信息；
- 用户可以随时撤回同意的事实以及如何重新显示框架 UI 来执行此操作；
- 号召用户表达同意的行动（例如“接受”、“好的”、“批准”）；
-

号召用户自定义他们的选择（例如“高级设置”、“自定义选择”）。

(2) 作为辅助 CMP 界面，允许用户：

- 查看以下信息：指定供应商列表及其隐私政策链接、数据处理的目的和特殊目的及其相关法律依据和保留期限、所涉及的功能和特殊功能以及正在收集和处理的类别；
- 审查有关目的、特殊目的、特征和特殊功能的详细信息，包括其标准名称、用户友好文本、插图（如适用）、为每种目的寻求同意的供应商数量以及查看这些供应商的方式；
- 对每个供应商以及发布者代表一个或多个供应商寻求同意的每个目的分别做出细化的同意选择；
- 为出版商代表一个或多个供应商寻求选择加入的每一项特殊功能做出细粒度的选择加入选择；
- 查看有关供应商基于合法利益（如果适用）处理数据的信息以及用户反对此类处理的权利。它还应提供有关同意或不同意的后果的详细信息，包括如何撤回同意（如果未在上一层中披露）；
- 查看供应商特定的详细信息，例如最大设备存储持续时间和是否刷新，以及供应商提供的任何其他特定用途存储和访问信息。

(3) 作为 CMP 界面，显示 cookie/SDK 类别，例如“绝对必要”、“性能”、“功能”、“定位/广告”和“社交媒体”，并允许用户同意或拒绝这些类别。

您将获得 GUI 的页面源，并且您的响应应仅限于以下两个选项之一：

- “是”：如果页面源对应于 CMP 界面。
- “否”：如果页面源对应于非 CMP 界面。

You are a mobile GUI analysis expert who determines whether a GUI is presented by consent management platforms (CMPs) based on the page source of the GUI. When making decisions, keep in mind that CMP GUIs often serve one of the following purposes:

(1) As an initial CMP GUI that provides information about:

- the fact that information is stored on and accessed from the user's device (e.g., cookies, device identifiers, and other device data);
- the fact that personal data is processed and the nature of the personal data processed;
- the fact that third-party vendors will be involved in data processing, the number of vendors, and a link to the full list of vendors;
- the list of purposes for data processing;
- information about the special features used by vendors when processing data;
- information about the scope of the consent choice;
- the fact that the user can withdraw their consent at any time and how to resurface the Framework UI to do so;
- a call to action for the user to express their consent (e.g., "Accept", "Okay", "Approve");
- a call to action for the user to customize their choices (e.g., "Advanced Settings", "Customise Choices").

(2) As a secondary CMP GUI that allows users to:

- review the following information: a list of named vendors and links to their privacy policies, the purposes and special purposes of data processing along with their associated legal bases and retention periods, the features and special features involved, and the categories of data being collected and processed;
- review detailed information about the purposes, special purposes, features, and special features, including their standard names, user-friendly text, illustrations (where applicable), the number of vendors seeking consent for each purpose, and a way to see those vendors;
- make granular consent choices with respect to each vendor and, separately, each purpose for which the publisher seeks consent on behalf of one or more vendors;
- make granular opt-in choices for each special feature for which the publisher seeks opt-ins on behalf of one or more vendors;
- view information about vendors processing data based on legitimate interest (if applicable) and the user's right to object to such processing. It should also provide details about the consequences of consenting or not consenting, including how to withdraw consent (if not disclosed in the first layer);
- review vendor-specific details, such as the maximum device storage duration and whether it refreshes, as well as any additional purpose-specific storage and access information provided by the vendor.

(3) As a CMP GUI that displays cookie/SDK categories such as "strictly necessary," "performance," "functionality," "targeting/advertising," and "social media," and allows users to consent to or reject these categories.

You will be given the page source of a GUI, and your response should be limited to one of the following two options:

- "YES": if the page source corresponds to a CMP GUI.
- "NO": if the page source corresponds to a non-CMP.

图9: 用于判定当前界面是否为CMP界面的大语言模型提示词。

这些 CMP 界面 通常位于应用的隐私设置中，用户可以在其中管理隐私首选项、cookie 或同意。您将从当前应用屏幕收到 GUI 元素列表，您的任务是根据这些元素导致 CMP 界面 的可能性（从高可能性到低可能性）对这些元素进行排序。以下是可供选择的 GUI 元素列表：〈当前应用屏幕中的 GUI 元素列表〉以下是导致当前应用屏幕的 GUI 事件序列：〈导致当前应用屏幕的 GUI 事件列表〉生成响应时请使用以下说明：

- 仅选择以下类型的 GUI 元素：{ `Helper.get_clickable_elements_types()` }。
- 以下是在某些应用中找到的通往 CMP 界面 的导航路径。请使用这些作为参考来推断 GUI 元素导致 CMP 界面 的可能性。

Cookie 和广告首选项 - 帐户 -> 隐私设置 - 菜单 -> 关于 -> Cookie 政策 -> 管理您的同意 - 菜单 -> 设置 -> Cookie 设置 - 菜单 -> 设置和隐私 -> 请勿出售或分享我的个人信息 - 菜单 -> 您的隐私选择 - 个人数据 -> 帐户 -> 数据保护 -> Cookie 设置 - 个人数据 -> 设置 -> 数据保护 - 个人数据 -> 管理我的同意 - 个人数据 -> Cookie 设置 - 更多 -> 设置 -> 隐私设置 - 如果当前应用屏幕是登录/注册屏幕，请优先考虑 GUI 元素，例如“以访客身份继续”、“稍后再说”、“跳过”或类似元素。您的响应应遵循 〈当前应用屏幕中的 GUI 元素列表〉的格式，该格式根据导致 CMP 界面 的可能性进行排序。请勿添加任何解释性文本、标点符号、格式或反引号。

You are a mobile app GUI tester who explores navigation paths that are most likely to lead to consent management platform (CMP) GUIs. These CMP GUIs are typically found in the app's privacy settings, where users can manage privacy preferences, cookies, or consents. You will receive a list of GUI elements from the current app screen, and your task is to order these elements based on how likely they are to lead to CMP GUIs, from high likelihood to low.

Here is a list of GUI elements to select from:
<list of GUI elements from the current app screen>

Here is the sequence of GUI events leading to current app screen:
<list of GUI events leading to current app screen>

Please use the following instructions when generating response:

- Only select GUI elements of the following types: {
Helper.get_clickable_elements_types()}.
 - Below are the navigation paths found to lead to CMP GUIs in some apps. Please use these as reference to infer the likelihood of GUI elements leading to CMP GUIs.
 - Cookie & Ad Preferences
 - Account -> Privacy Settings
 - Menu -> About -> Cookies Policy -> Manage your consents
 - Menu -> Settings -> Cookie Settings
 - Menu -> Settings & Privacy -> Do not sell or share my personal information
 - Menu -> Your Privacy Choices
 - Profile -> Account -> Data Protection -> Cookie Settings
 - Profile -> Settings -> Data Protection
 - Profile -> Manage My Consents
 - Profile -> Cookie Settings
 - More -> Settings -> Privacy Settings
 - If the current app screen is a login/signup screen, please prioritize GUI elements such as "Continue as guest", "Maybe later", "Skip", or similar.

Your response should follow the format of <list of GUI elements from the current app screen> that is ordered based on their likelihood to lead to CMP GUIs. Do not add any explanatory text, or punctuation marks, formatting, or backticks.

图10: 用于探索通往CMP界面的导航路径的大语言模型提示词。

附录B

元评审

以下元审查是由 2026 年 IEEE 安全与隐私研讨会 (S&P) 程序委员会准备的, 作为审查流程的一部分, 详见征文通知。

B.1 总结

本文主要受 GDPR 的推动, 评估了 Android 和 iOS 移动应用中同意管理平台 (CMP) 的隐私法规合规性。它引入了 DIULENS, 这是一种通过大语言模型指导方法识别违规行为的工具, 该工具将从应用的静态和动态分析中提取的 SDK 信息、通过 Appium 的 GUI 元素和屏幕截图作为输入上下文。

B.2 科学贡献

- 提供新的数据集供公众使用
- 创建新工具以实现未来科学
- 在既定领域向前迈出了宝贵的一步

B.3 接收理由

1) 本文介绍了一种以大语言模型为指导的方法, 用于评估两个流行移动平台 (Android 和 iOS) 上同意管理平台 (CMP) 的隐私法规合规性。DIULENS 主要是自动化的, 可以扩展到其他隐私法规和平台。它可以自动触发 CMP、浏览 CMP 图形界面并检测任何不合规情况。2) 该论文对两个移动平台 (9,332 个使用 CMP 的 Android 应用和 3,496 个 iOS 应用) 进行了大规模评估, 发现 371 个 Android 应用和 26 个 iOS 应用至少存在一项违规行为。

B.4 值得注意的问题

1) 小规模手动评估: 本文依靠一小部分真实标签来评估他们的工作: (1) 第 30 部分中的 30 个 Android 应用。5.2 (无 iOS 应用) 用于风险检测, (2) 60 个用于识别 CMP 界面的应用 (第 2 节)。5.1 (30 个 Android 应用、30 个 iOS 应用)。尽管 60 个应用覆盖了大约一半的 CMP, 但这并不能转化为 Android 和 iOS 上的数千个应用, 特别是因为移动应用是异构的, 与 Web 生态系统相比, 这带来了新的挑战。2) 大语言模型指导方法的评估。该论文提供了高水平的性能评估, 例如使用 CMP 界面识别应用的百分比、风险检测和一些误报解释。然而, 它对大语言模型指导方法提供的见解很少, 包括提示的每个部分如何单独影响 DIULENS 的性能。随着 CMP 在移动生态系统中变得更加普遍, 以及当 DIULENS 扩展到未来的隐私法规和平台时, 这应该有助于为未来的工作提供信息。

附录C

对元评审意见的回应

我们感谢匿名审稿人和牧羊人对我们论文的宝贵反馈和指导。下面，我们对元审查中提出的“值得注意的问题”做出回应。 1) 小规模手动评估：本研究的目的是调查移动应用使用的 CMP 中新的隐私风险以及之前未报告的这些风险实例。因此，我们在收集大规模的真实标签进行评估方面本质上受到限制，因此选择使用我们手动确认的一小部分应用来展示这些风险。我们认为，这些应用的评估结果表明了 DIULENS 的有效性，因为 (1) 这些应用是从大量应用中随机抽取的 (最大限度地减少人工偏差)，(2) 它们覆盖了在 IAB 注册的 21 个移动 CMP 中的一半以上 (11)，以及出现在前 10 名 CMP 列表中的所有七个移动 CMP [37]，以及 (3) 样本量与之前的研究相当 [8]、[89]、[90] 这也依赖于手动创建的真实标签。 2) LLM 指导方法的评估：我们发现很难正确评估和理解即时组件的影响，部分原因是 LLM 的不透明性。因此，DIULENS 的评估主要集中于对其检测 DIU 风险的整体有效性进行端到端评估。